

Securitatea Rețelelor de Calculatoare

Ion BICA, PhD, CISA

ion.bica@mta.ro



Obiective

- **Prezentarea tehnologiilor și produselor ce pot fi utilizate pentru a asigura securitatea rețelelor de calculatoare**
- **Prezentarea metodologiilor și a instrumentelor ce pot fi folosite pentru testarea securității rețelelor de calculatoare**
- **Acumularea cunoștințelor necesare pentru proiectarea și implementarea de soluții de securitate pentru rețele de calculatoare**

Conținut

1. **Sisteme firewall**
2. **Sisteme pentru detectarea / prevenirea intruziunilor**
3. **Securitatea la nivel LAN**
4. **Securitatea rețelelor wireless**
5. **Testarea securității rețelelor**

Bibliografie

- Lydia Parziale, David T. Britt, Chuck Davis, “TCP/IP Tutorial and Technical Overview”, IBM Redbooks, 2006
 - <http://www.redbooks.ibm.com/abstracts/gg243376.html>
- William Stallings, “Network Security Essentials: Applications and Standards, 6th Edition”, Pearson, 2017
- Michael Stewart, Denise Kinsey, “Network security, firewalls, and VPNs”, Jones & Bartlett Learning, 2020
- Wenliang Du, “Internet Security: A Hands-on Approach, 3rd Edition”, 2022
- NIST Special Publications
- Resurse disponibile pe Internet

Detalii organizatorice

- **Număr de ore: 14 Curs + 14 Lab**
- **Examen**
 - test grilă
- **Informațiile aferente cursului vor fi disponibile în format electronic**
 - note de curs / laborator
 - documentație auxiliară



1. Systeme Firewall



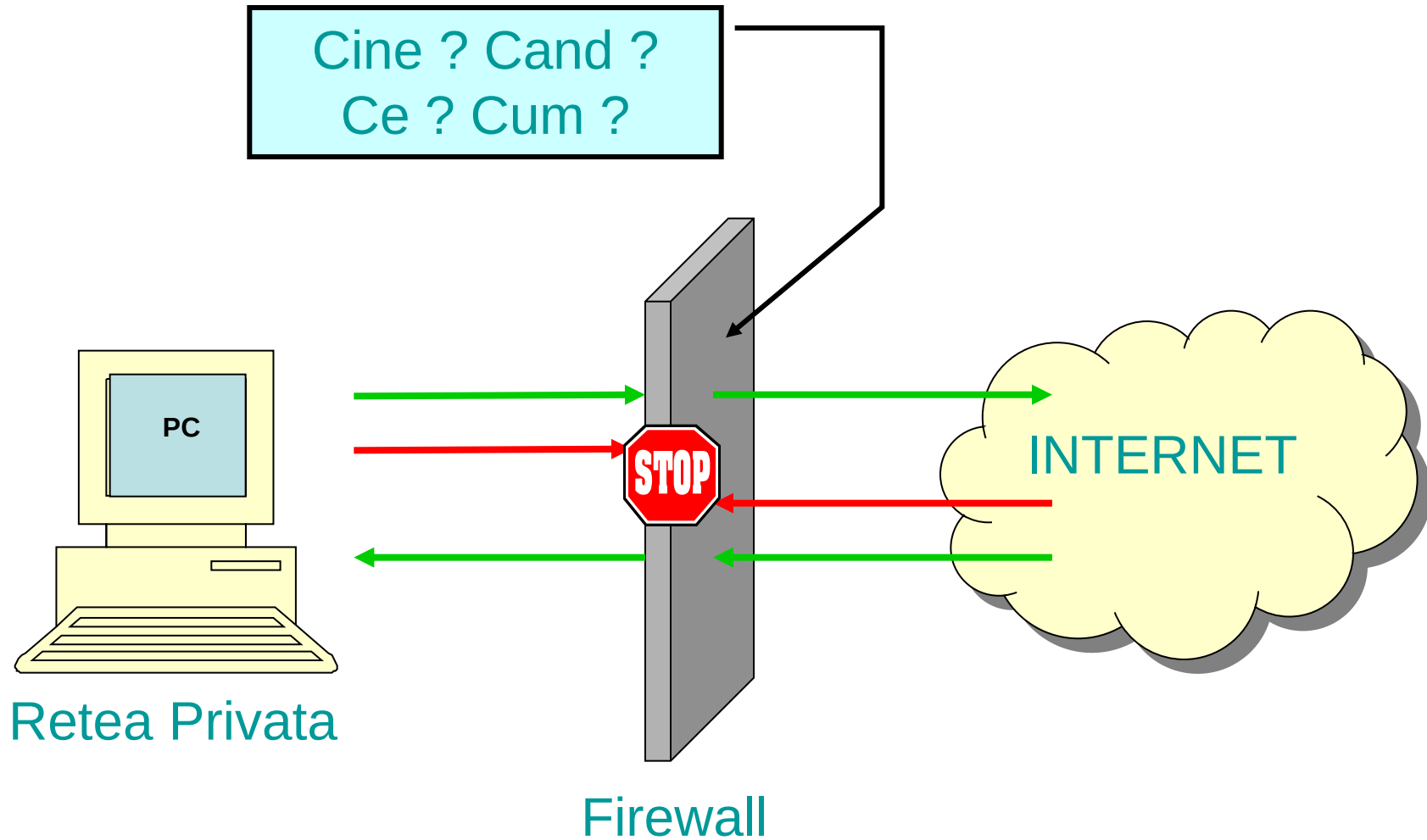
Sisteme firewall

- Conectarea la Internet este o cerință de business pentru majoritatea organizațiilor
- Un calculator conectat direct la Internet este o țintă posibilă pentru atacatori
- Orice disfuncționalitate a sistemelor de calcul costă bani (direct sau indirect)
- Sunt necesare mecanisme de protecție a rețelelor interne împotriva atacurilor externe

Rolul unui firewall

- O manifestare fizică a politicii de securitate în rețea
- Punct de control și monitorizare a traficului între două rețele
- Mecanism pentru limitarea accesului la resursele/serviciile din rețeaua internă
- Similar unui “zid de apărare”

Rolul unui firewall (cont.)



Cerințe pe care trebuie să le satisfacă un firewall

- 1. Tot traficul din interior spre exterior și vice versa trebuie să treacă prin firewall**
 - nu trebuie să existe puncte de acces în rețea necontrolate (backdoors)
- 2. Numai traficul autorizat, stabilit prin politica de securitate internă, poate să treacă prin firewall**
 - reguli de acces stricte
- 3. Firewall-ul însuși trebuie să fie imun la atacuri. Aceasta presupune folosirea unui sistem de încredere care a fost supus în prealabil unui proces de securizare (hardening)**
 - mașini dedicate pe care nu trebuie să mai ruleze alte servicii

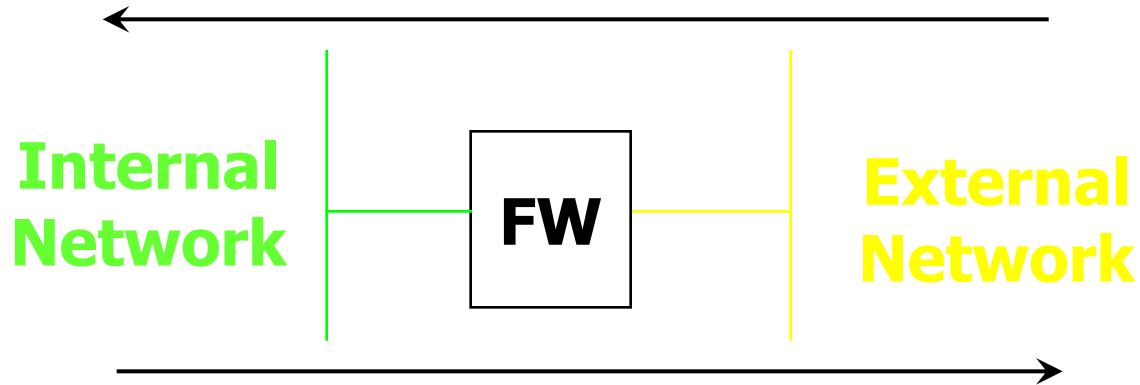
Terminologie

- **Pachet** – unitatea de informație creată de un protocol de rețea pentru a transporta date și informații de control. În contextul stivei TCP/IP se mai numește și datagramă.
- **DMZ (DeMilitarized Zone)** – un segment de rețea dispus între exterior (Internet) și rețeaua internă, având rolul de a intermedia schimbul de informații. Este rețeaua în care, de regula, sunt dispuse serviciile publice (Web, Mail, DNS, etc).
- Rețele protejate și neprotejate
 - **Rețelele protejate** sunt localizate în spatele unui firewall, fiind protejate prin politicile acestuia
 - **Rețelele neprotejate**, cum ar fi Internet-ul, stau în fața unui firewall și nu sunt protejate de către politicile acestuia
- Direcții ale traficului
 - **Inbound** = spre interiorul zonei protejate de firewall
 - **Outbound** = spre exteriorul zonei protejate de firewall

Terminologie (cont.)

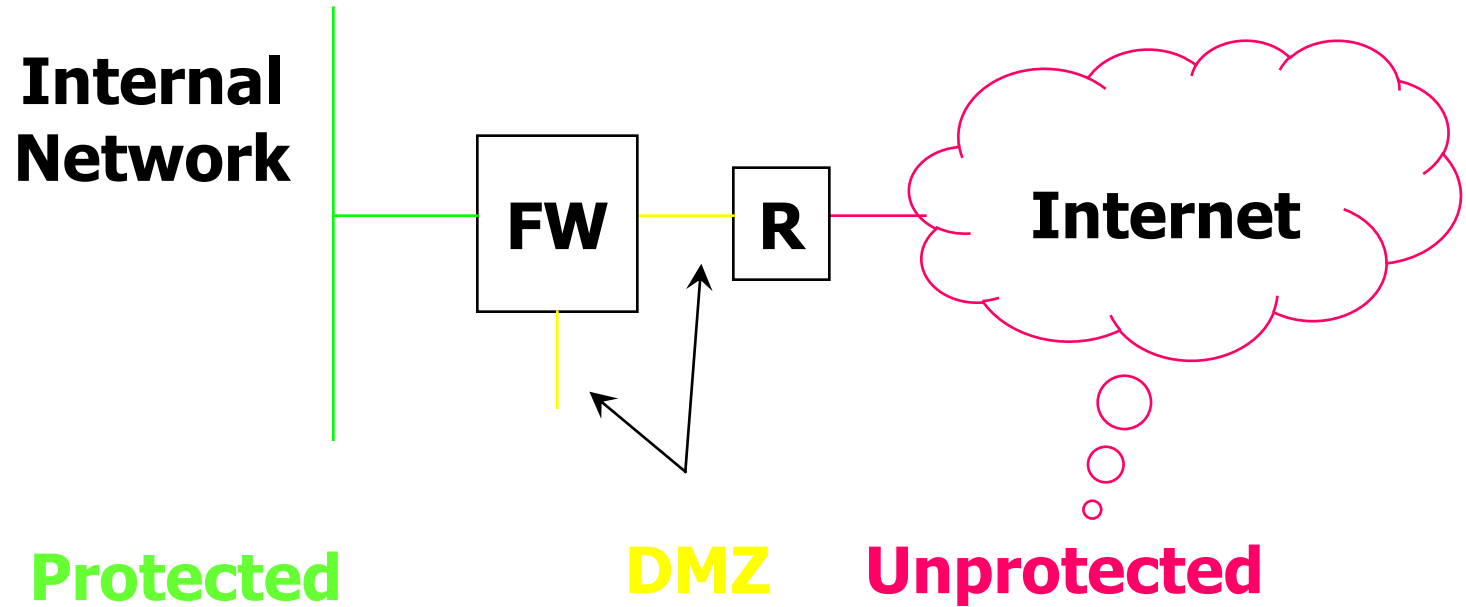
- **Inbound vs. Outbound**

- **Inbound** = spre interiorul zonei protejate de firewall

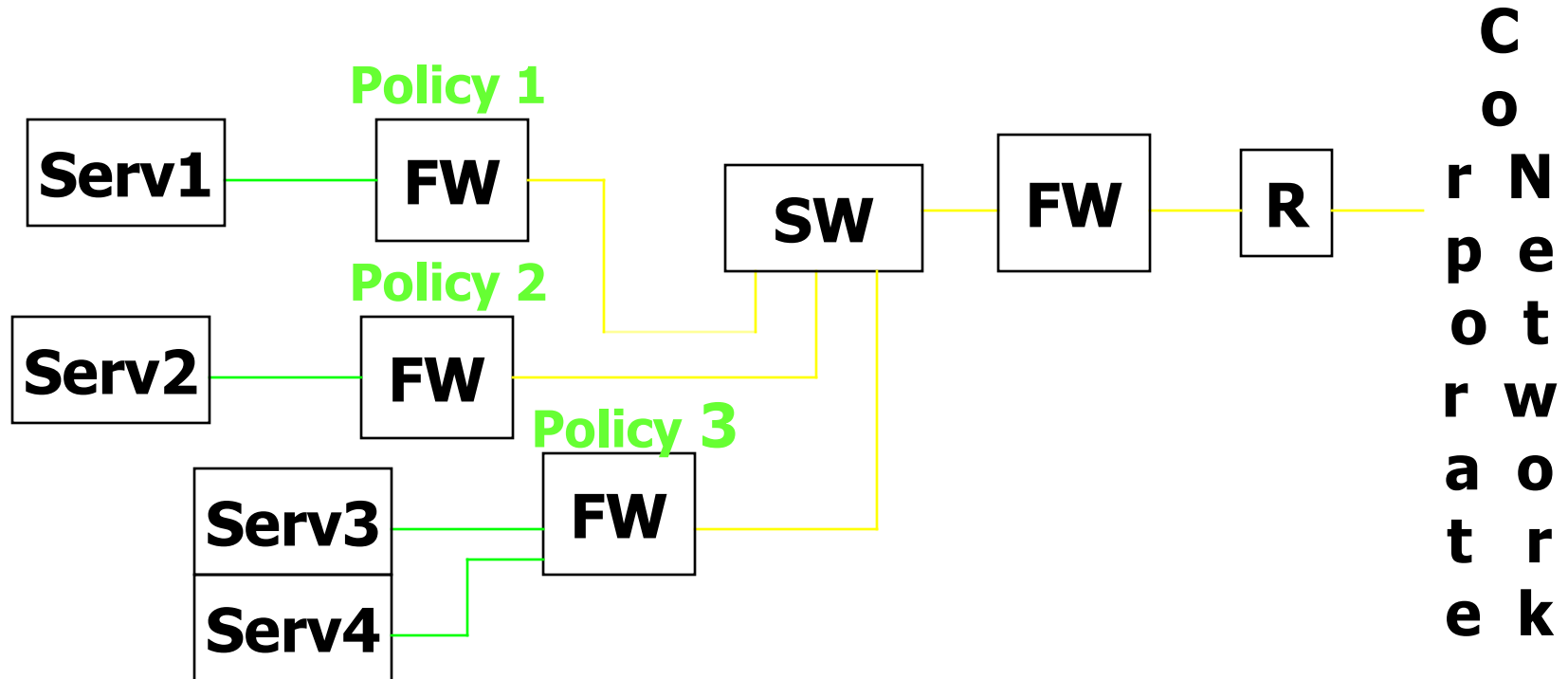


- **Outbound** = spre exteriorul zonei protejate de firewall

Exemplu de firewall



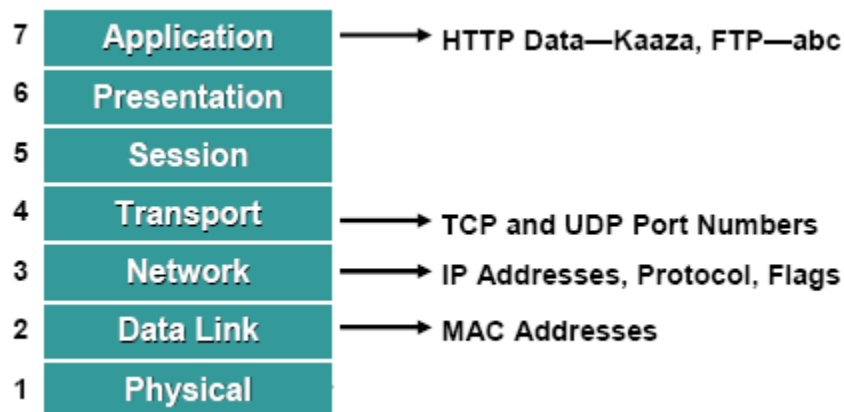
Exemplu de firewall (cont.)



Politici de firewall

- **Pe bază de blacklist-uri (default-allow)**
 - toate pachetele sunt permise, cu excepția celor care se încadrează în regulile de filtrare și care sunt respinse
 - flexibilitate mare
 - pot exista cazuri în care traficul malițios trece prin firewall
- **Pe baza de whitelist-uri (default-deny)**
 - toate pachetele sunt respinse, cu excepția celor care sunt permise explicit prin regulile de filtrare
 - trebuie definită câte o regulă pentru fiecare tip de trafic
 - abordare mai sigură

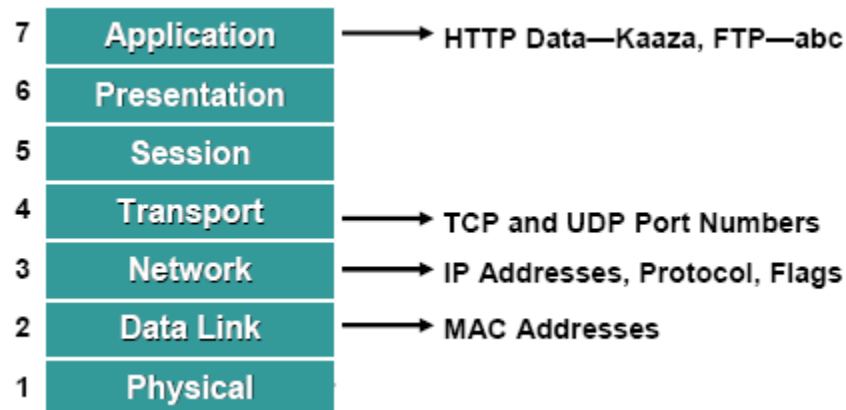
Parametri de control al accesului



Exemple de politici (reguli):

- La nivel legătură de date
 - Interzice toate pachetele de la adresa MAC 00-1c-bf-01-02-03
 - Nu cere autentificarea dacă adresa MAC este 00-1c-2b-aa-bb-cc
- La nivel rețea
 - Interzice orice trafic, cu excepția pachetelor de ieșire ce vin de la rețeaua 10.10.10.0/24
 - Permite numai trafic ESP (IPsec)
 - Interzice orice trafic, cu excepția traficului de la rețeaua 172.16.30.0/24, spre rețeaua 192.168.10.0/24

Parametri de control al accesului (cont.)



Exemple de politici (reguli):

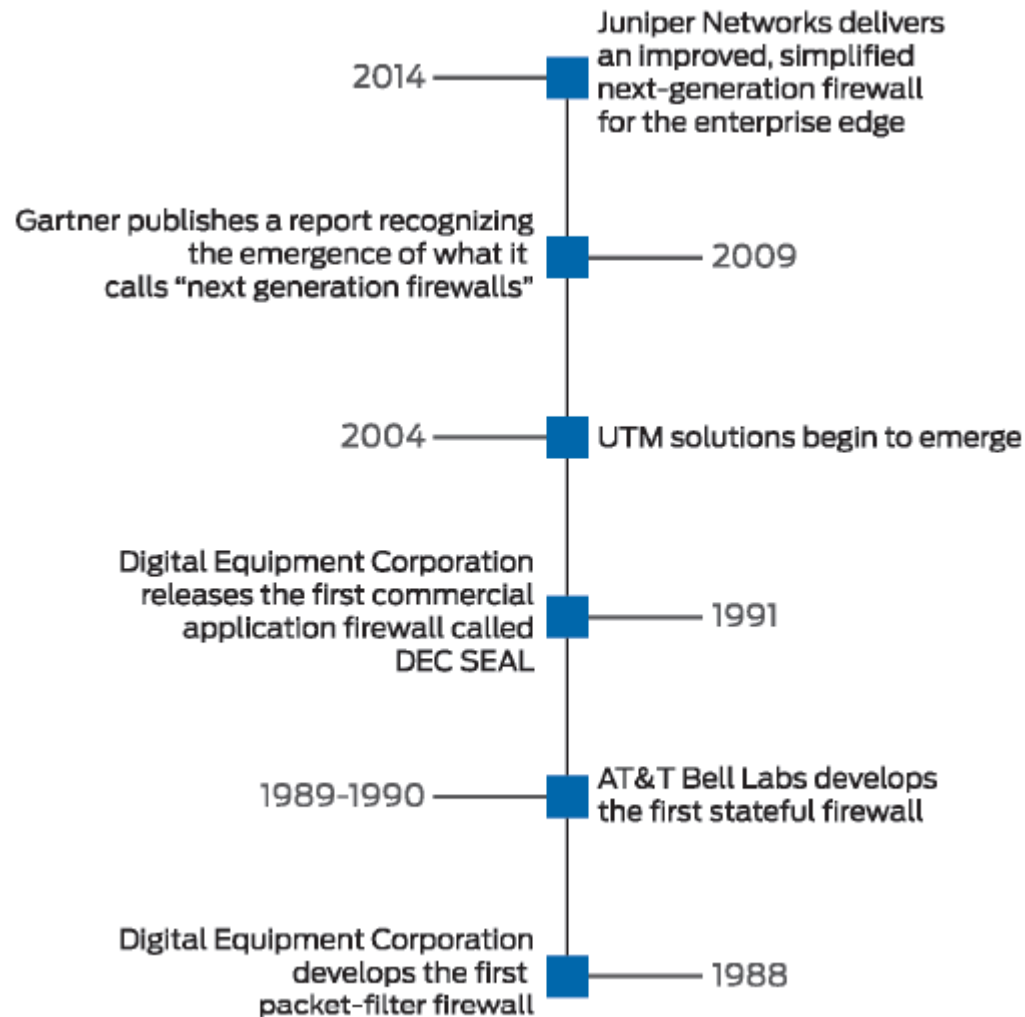
- **La nivel transport**
 - Permite traficul de Web de oriunde (inclusiv Internet), cu condiția ca adresa destinație să fie a serverului propriu – 192.168.0.10
 - Permite traficul FTP de oriunde spre propriul server – 192.168.0.11
- **La nivel aplicație**
 - Nu permite trafic HTTP în al cărui header există comanda “POST”
 - Nu permite opțiunea “DEBUG” în comenzile SMTP (e-mail)

Tipuri de firewall

- **Packet Filtering Firewall**
- **Stateful Inspection Firewall**
- **Proxy Firewall**
- **Next-Generation Firewall (NGFW)**

- **Network-Based Firewall**
- **Host-Based Firewall**

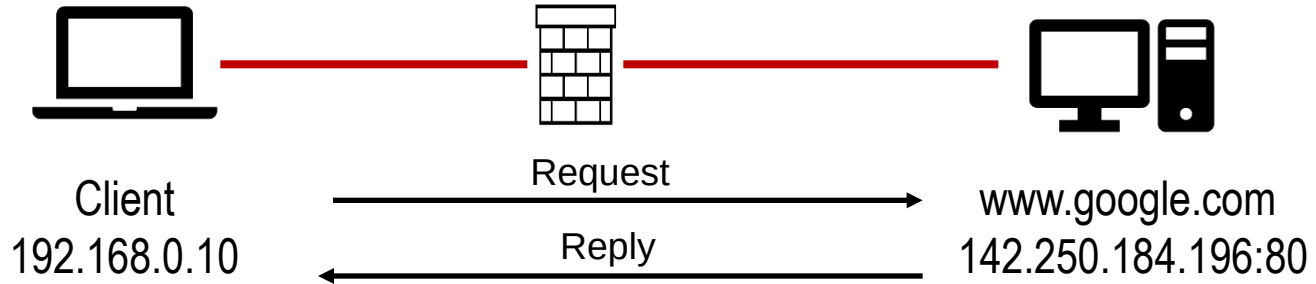
Cronologia firewall



Packet Filtering Firewall

- Permite sau interzice pachetele funcție de adresă sau port
 - reguli de filtrare (ACL – Access Control List): *deny / allow*
 - regula default: *deny all*
- Verificarea pachetelor se face în ambele direcții (*inbound* respectiv *outbound* trafic)
- Payload-ul pachetelor (zona de date) nu este inspectat
- Nu memorează informații de stare
 - pachetele sunt tratate individual, fără a ține cont de context
- Funcție suportată de majoritatea ruterele actuale
- Avantaje
 - simplu, rapid, transparent pentru utilizatori
- Dezavantaje
 - nu poate bloca toate tipurile de trafic
 - ineficient împotriva atacurilor care exploatează vulnerabilități ale protocoalelor din stiva TCP/IP
 - eficiență scăzută în cazul fragmentării pachetelor

Packet Filtering Firewall (cont.)



- **Sunt necesare două reguli pentru a permite traficul între client și server:**
 1. `tcp ip src 192.168.0.10 ip dst 142.250.184.196 port dst 80 allow`
 2. `tcp ip src 142.250.184.196 port src 80 ip dst 192.268.0.10 allow`

Stateful Inspection Firewall

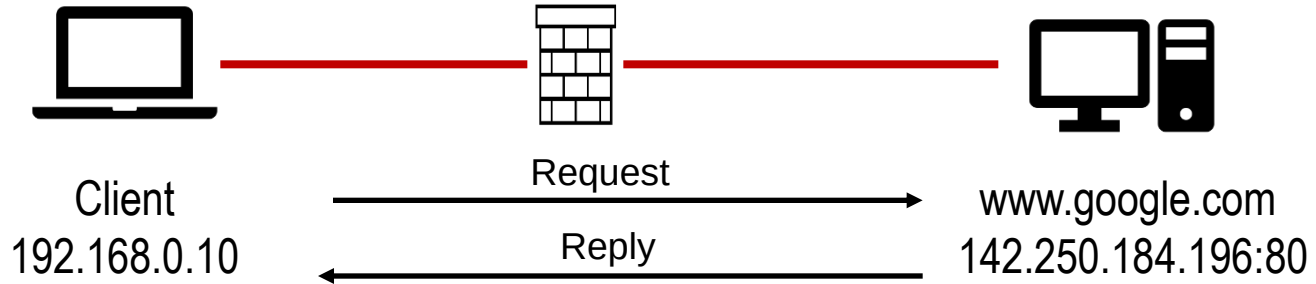
- Bazat tot pe filtrarea de pachete
- Inspectează pachetele și memorează informații de stare pentru fiecare conexiune în parte
 - odată ce un pachet este identificat ca făcând parte dintr-o conexiune stabilită, procesarea acestuia poate fi optimizată (lua o cale mai scurtă)
 - informația de stare ce se memorează diferă de la producător la producător
- Eficiență crescută în blocarea atacurilor

Stateful Inspection Firewall (cont.)

Source Address	Source Port	Destination Address	Destination Port	Connection State
192.168.1.100	1030	192.0.2.71	80	Initiated
192.168.1.102	1031	10.12.18.74	80	Established
192.168.1.101	1033	10.66.32.122	25	Established
192.168.1.106	1035	10.231.32.12	79	Established

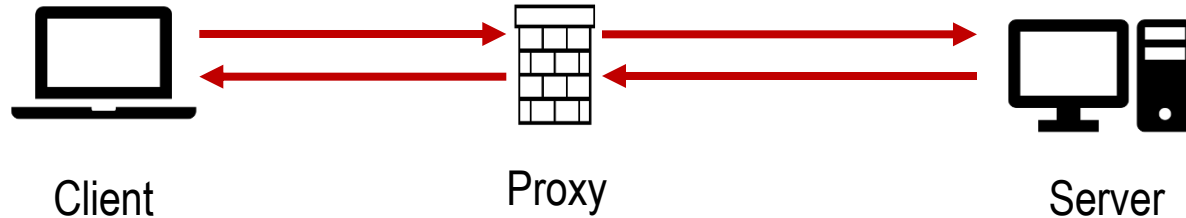
- Fiecare pachet primit este analizat în conformitate cu conținutul tabelii de stare:
 - dacă starea pachetului corespunde stării din tabel, atunci pachetul este lăsat să treacă
- Mașini de stare pentru fiecare protocol (TCP, UDP, etc)
 - blocarea pachetelor care nu aderă strict la starea mașinii din momentul respectiv (de exemplu, numărul de secvență TCP este în afara ordinii)
- Ce se întâmplă în cazul protocoalelor de tip connectionless (UDP)?
 - se urmărește doar adresele și porturile sursă și destinație
 - un răspuns DNS va fi lăsat să treacă numai dacă a existat în prealabil o interogare DNS
 - intrările din tabelă sunt șterse automat după un interval de timp

Stateful Inspection Firewall (cont.)



- Este suficientă o singură regulă pentru a permite traficul între client și server :
 1. `tcp ip src 192.168.0.10 ip dst 142.250.184.196 port dst 80 allow`

Proxy Firewall



- Un proxy firewall acționează ca un intermediar între client și server
 - două conexiuni separate: client-proxy, proxy-server
 - toate cererile și răspunsurile trec prin proxy unde sunt validate
- Inspectează și filtrează traficul la nivel aplicație
- Caching pentru creșterea performanței
- Forward Proxy
 - protejează clienții interni prin medierea traficului de ieșire
 - Squid
- Reverse Proxy
 - protejează serverele interne prin medierea traficului de intrare
 - Nginx, HAProxy
- Transparent Proxy
 - interceptează traficul fără a necesita configurări la nivel de client
 - nu modifică cererile clienților
- Application Layer Proxy
 - deep packet inspection și content filtering

Web Application Firewall

- **Asigură protecția aplicațiilor Web prin monitorizarea și filtrarea traficului HTTP/S**
 - SQL injection, XSS, CSRF, etc.
- **Operează ca și un reverse proxy**
- **Network-Based WAF**
- **Host-Based WAF**
- **Exemple de produse:**
 - F5 Advanced WAF
 - Imperva WAF
 - Modsecurity (open source)

Next-Generation Firewall (NGFW)

- Cel mai performant tip de firewall
- Integrează funcții tradiționale de firewall cu caracteristici suplimentare de securitate
 - Application Control
 - Intrusion Prevention System (IPS)
 - Deep Packet Inspection (DPI)
 - Threat Intelligence
 - SSL/TLS Inspection
 - Sandboxing
- Necesită plata unui abonament pentru a putea detecta cele mai recente tipuri de atacuri!

Alte tehnologii

- **Network Access Control (NAC) / Network Acces Protection (NAP)**
 - verificarea calculatoarelor utilizatorilor înainte de a le da accesul în rețeaua internă
 - calculatorul este pus inițial într-o "zonă de carantină" (rețea specială), verificat din punct de vedere al securității (antivirus, update-uri, etc) și apoi i se permite accesul în rețeaua internă

- **Unified Threat Management (UTM)**
 - implementarea mai multor funcționalități de securitate pe un singur echipament (firewall, IDS, antivirus, VPN)
 - reduce efortul de administrare
 - limitări din punct de vedere al performanței

Caracteristici cheie pentru un firewall

- **Hardware vs. software firewall**
 - appliance cu sistem de operare specializat
 - masină fizică sau virtuală cu sistem de operare de uz general
- **Performanța**
 - viteza de procesare (bps, pps, cps)
 - scalabilitatea
- **Politici de filtrare suportate**
 - pe bază de adrese și protocoale
 - funcție de aplicațiile de rețea utilizate
 - pe baza identității utilizatorilor
- **Disponibilitatea**
 - activ-pasiv
 - activ-activ
- **Integrarea cu infrastructura existentă**
 - cu serviciile de autentificare (Radius, Tacacs+)
 - cu serviciile de logging și monitorizare
- **Management**
 - SSH, HTTPS

Limitările unui firewall

- **Nu asigură protecție împotriva atacurilor interne**
 - 70 % din atacuri sunt din interior!
- **Protecție limitată împotriva zero-day attacks**
 - se bazează pe reguli și semnături predefinite pentru a detecta atacuri
- **Nu pot inspecta traficul criptat / tunelat**
- **Nu pot bloca atacuri de tip phishing sau link-uri malițioase**
- **Sisteme complexe**
 - configurarea și administrarea unui firewall nu este simplă!

Produce firewall

- **Linux netfilter/iptables**
- **Linux pfSense**
- **Palo Alto Networks PA/VM**
- **Fortinet FortiGate**
- **Check Point FireWall-1**
- **Cisco Firepower**
- **Juniper NetScreen**

Gartner Magic Quadrant for Enterprise Network Firewalls

Figure 1: Magic Quadrant for Network Firewalls



Source: Gartner (December 2022)

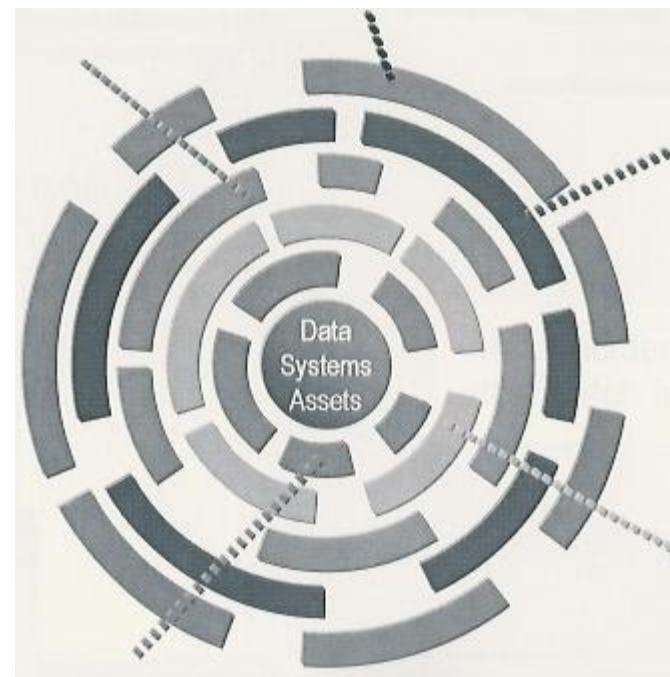


2. Sisteme pentru Detectarea / Prevenirea Intruziunilor (IDS/IPS)



Necesitatea utilizării unui IDS

- Cea de-a doua linie de apărare după firewall
 - principiul apărării în adâncime (*defence in depth*)
 - o serie de atacuri nu pot fi stopate de către firewall (CodeRed, Nimda, etc)



Necesitatea utilizării unui IDS (cont.)

- **Detectează atacuri ce nu pot fi prevenite de către celelalte mecanisme de securitate**
- **Oferă o imagine asupra atacurilor la care este supusă în mod curent o organizație**
- **Instrument de măsură a eficienței mecanismelor de securitate implementate**
- **Furnizează dovezile necesare pentru tragerea la răspundere a atacatorilor**

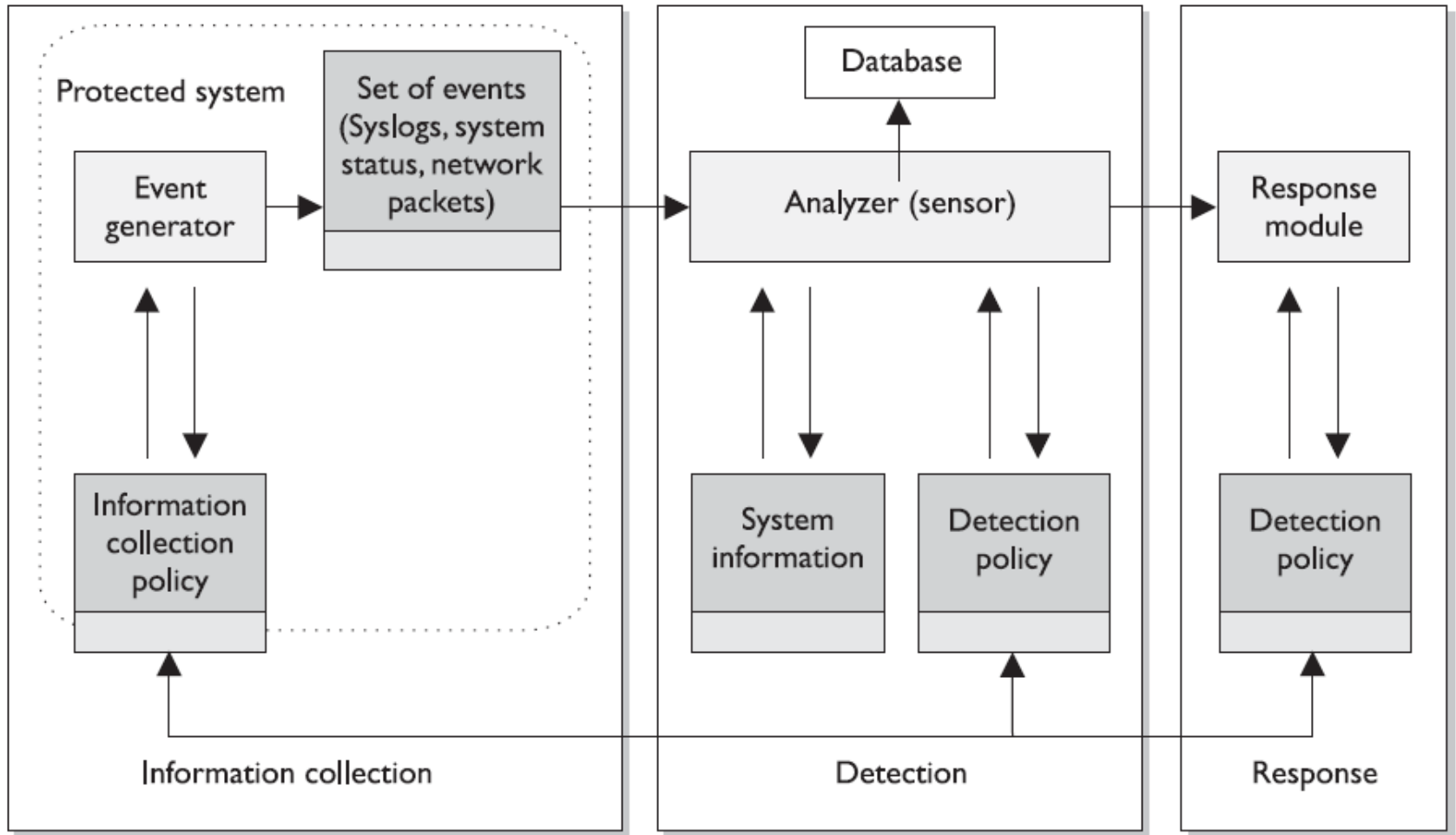
Definiții

- ***Intruziune***
 - set de acțiuni având ca obiectiv compromiterea securității unui calculator
- ***Detectarea intruziunilor (intrusion detection)***
 - procesul de identificare și combatere a intruziunilor
- ***Sisteme pentru detectarea intruziunilor (IDS)***
 - unelte și metode ce ajută la identificarea, evaluarea și raportarea intruziunilor
 - echivalent cu sistemele de securitate fizică: camere de supraveghere, senzori de mișcare, etc
- ***Sisteme pentru prevenirea intruziunilor (IPS)***
 - IDS cu capabilități de stopare a intruziunilor

Terminologie

- fals pozitiv (*false positive*)
 - activitățile normale sunt considerate atacuri
- fals negativ (*false negative*)
 - activitățile malițioase nu sunt detectate
- atac de tip “*low and slow*”
- atac / virus “*in the wild*”
- atac / virus “*in the zoo*”

Arhitectura unui IDS



Tipuri de IDS

- **Funcție de modul de colectare a evenimentelor**
 - IDS la nivel rețea (*NIDS - Network-based IDS*)
 - IDS la nivel host (*HIDS - Host-based IDS*)
- **Funcție de mecanismul de detecție folosit**
 - IDS bazat pe semnături (*signature-based detection*)
 - IDS bazat pe anomalii (*anomaly-based detection*)
- **Funcție de modul de răspuns la intruziuni**
 - IDS pasiv
 - IDS activ

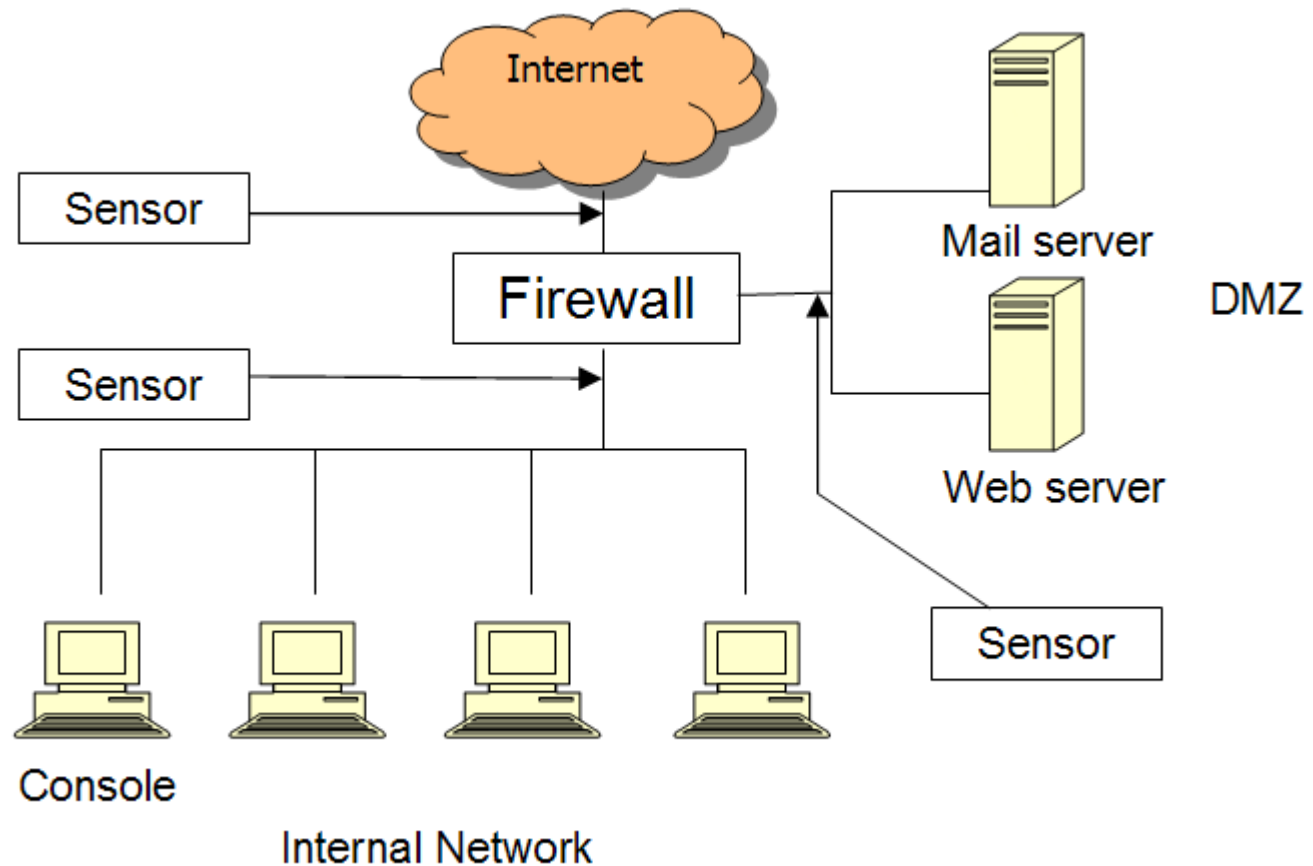
IDS la nivel rețea

- **Monitorizarea traficului din rețea**
 - captare și analiză pachete
- **Senzori cu interfețe de rețea ce operează în *promiscuous mode***
- **Tehnici de captare a traficului de rețea**
 - SPAN Port
 - TAP
 - Network Packet Broker
- **Permit detecția atacurilor de scanare de porturi, DoS, propagare malware sau încercări de acces neautorizat**

IDS la nivel rețea (cont.)

- **Avantaje:**
 - scalabilitate ridicată (cu câțiva senzori bine plasați se poate monitoriza o rețea întreagă)
 - nu afectează performanțele sistemelor monitorizate
 - poate opera astfel încât să fie invizibil pentru atacatori (*stealth mode*)
- **Dezavantaje:**
 - nu protejează sistemele împotriva utilizatorilor interni
 - pot rata pachete în cazul unui volum mare de trafic (~Gbps)
 - folosirea mai multor senzori în paralel
 - implementarea hardware a funcțiilor critice (appliances)
 - nu poate analiza traficul criptat (VPN)
 - poate identifica doar faptul că un atac a fost inițiat nu și dacă a avut succes

IDS la nivel rețea (cont.)



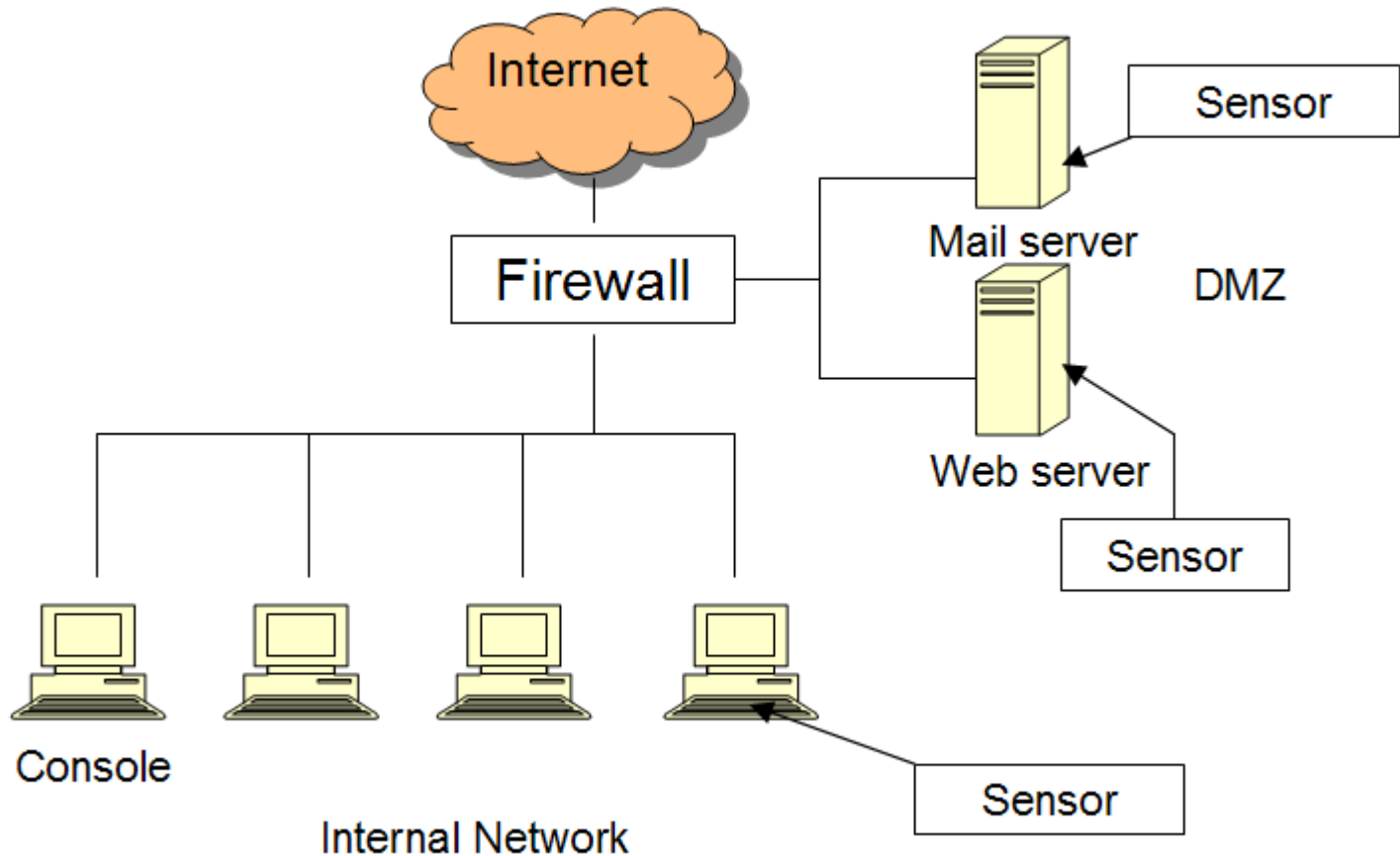
IDS la nivel host

- **Monitorizarea evenimentelor din cadrul unui sistem de calcul**
 - analiza log-uri, procese active
- **Verificarea integrității fișierelor**
 - sume de control criptografice ce sunt calculate periodic și comparate cu valorile de referință
 - Tripwire, AIDE, Afick
- **Permite detectarea atacurilor precum și evaluarea pagubelor produse de acestea**

IDS la nivel host (cont.)

- **Avantaje:**
 - nu necesită echipamente suplimentare – se instalează pe sistemele monitorizate
 - pot detecta atacuri ce nu pot fi văzute de către un NIDS (ex. trojan horse)
 - funcționează și în cazul criptării traficului
- **Dezavantaje:**
 - scalabilitate redusă
 - afectează performanța sistemelor monitorizate
 - odată compromis sistemul, IDS-ul poate fi dezactivat
 - nu poate detecta atacuri de scanare a rețelei, DoS, etc

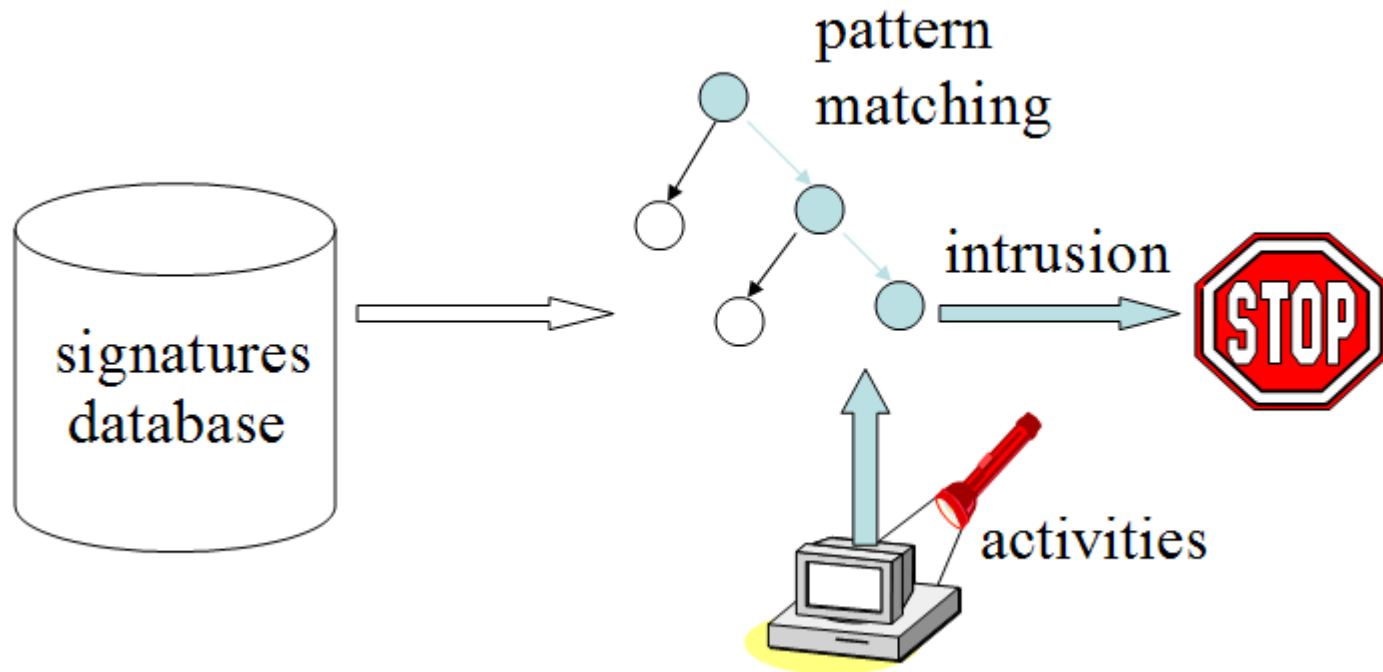
IDS la nivel host (cont.)



IDS bazat pe semnături

- Similar sistemelor antivirus
- Fiecare atac cunoscut până în momentul de față are o semnătură
 - secvență specifică de octeți în cadrul pachetelor de rețea
 - pattern în cadrul fișierelor de log
 - valoare hash pentru fișierele malițioase
- IDS dispune de o bază de date de semnături ce trebuie actualizată periodic
- Presupune acumularea de cunoștințe despre fiecare atac în parte pentru construirea semnăturii
 - knowledge based IDS
- Cel mai răspândit tip de IDS

IDS bazat pe semnături (cont.)



IDS bazat pe semnături (cont.)

- **Avantaje:**

- eficiența sistemului depinde modul în care este actualizată baza de date de semnături
- număr relativ scăzut de alarme de tip *false positive*
- oferă informații detaliate despre tipul de atac

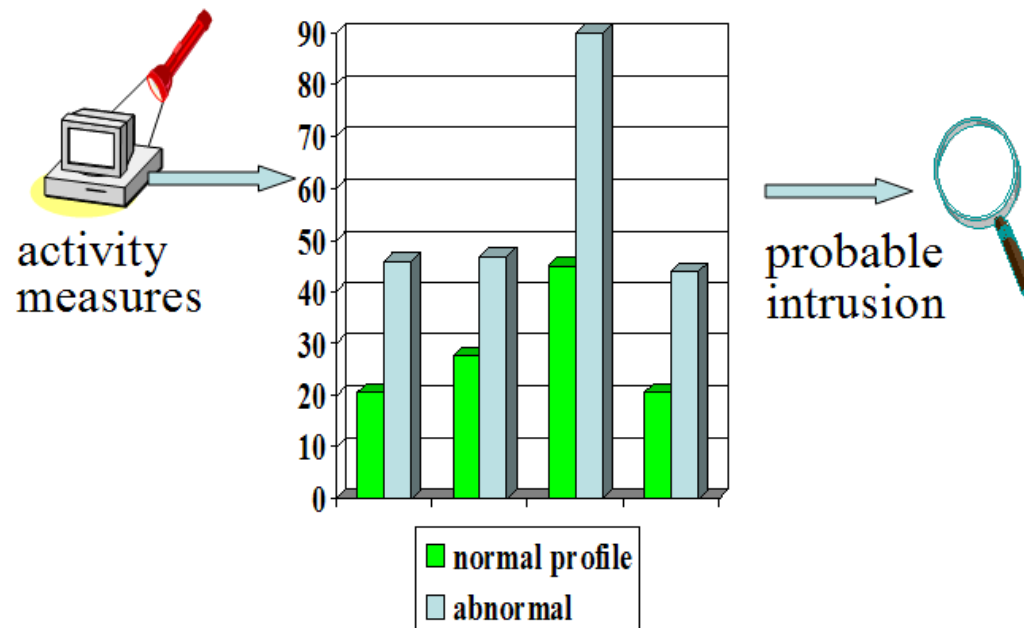
- **Dezavantaje:**

- nu poate detecta noi tipuri de atacuri
- cu cât baza de date de semnături este mai mare cu atât sistemul este mai lent (implementări hardware)

IDS bazat pe anomalii

- **Anomalie = deviere de la starea normală**
- ***Learning mode* – construirea unui profil al stării normale a sistemului**
 - acuratețea profilului depinde de durata procesului de învățare
 - pe durata procesului de învățare, nu trebuie să existe atacuri în sistem
- ***Detection mode* – compararea stării curente cu cea prestabilită**
 - o deviere mare față de starea normală este interpretată drept un posibil atac ce trebuie investigat
- ***Analiză statistică* – identificarea deviațiilor (anomaliilor)**
 - calcularea abaterii standard
 - folosirea de algoritmi de învățare automată (machine learning)

IDS bazat pe anomalii (cont.)



IDS bazat pe anomalii (cont.)

- **Network Behavior Anomaly Detection (NBAD)**
 - monitorizarea traficului pentru vedea cine cu cine dialoghează
 - analiza modului de derulare a protocoalelor de rețea (formatul pachetelor, ordinea în care acestea sunt transmise, etc)
 - consumul de resurse (lățime de bandă, încărcarea procesoarelor, etc)
- **User Entity Behavior Analytics (UEBA)**
 - analiza activității utilizatorilor (login patterns)

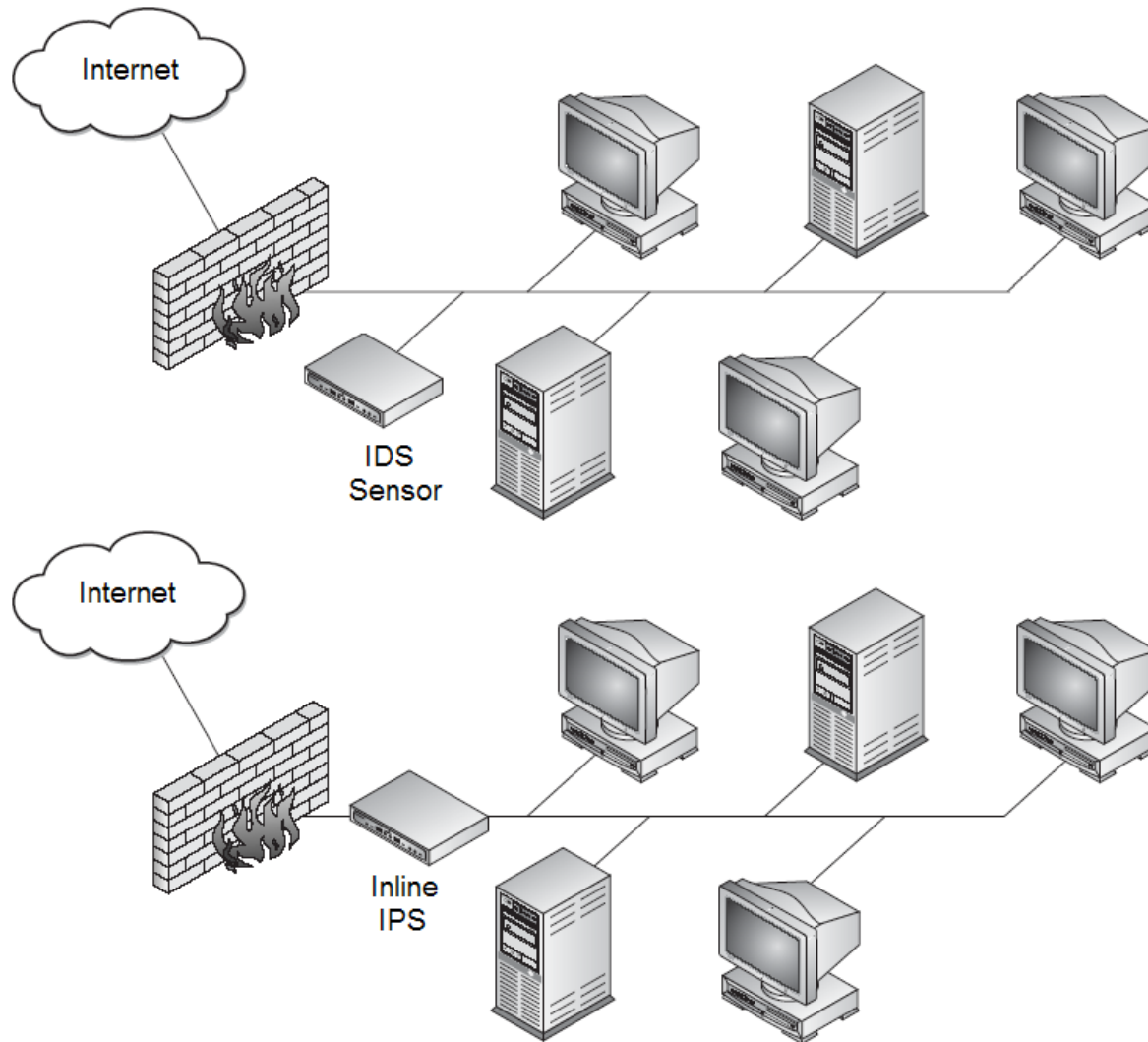
IDS bazat pe anomalii (cont.)

- **Avantaje:**
 - pot detecta tipuri noi de atacuri
- **Dezavantaje:**
 - număr relativ mare de alarme de tip *false positive*
 - configurația sistemelor se modifică în mod constant!
 - transmite alarme generice
 - personal specializat pentru investigarea cauzelor!

Răspunsul la atacuri

- **Răspunsuri pasive**
 - alarme și notificări
 - trape SNMP
- **Răspunsuri active**
 - resetare conexiune
 - modificare ACL din router / firewall

IDS vs. IPS



Caracteristici cheie pentru un IDS/IPS

- **Colectare de informații**
 - tipuri de senzori
 - volumul de trafic analizat
- **Capabilități de detecție / prevenție**
 - definire reguli de detecție, blacklists, whitelists
 - acuratețea detecției (numărul de falsuri pozitive / negative)
- **Modularitate**
 - plugin-uri pentru modificarea / extinderea funcționalităților
- **Jurnalizare**
 - locală (fișier de log)
 - centralizată (syslog)
- **Management**
 - separarea rolurilor
 - consolă de administrare

Limitările IDS/IPS

- Majoritatea IDS/IPS actuale folosesc ca mecanism de detecție semnăturile și anomaliile de protocol
- Efortul de administrare al unui IDS/IPS este destul de ridicat
 - tuning, investigare alarme, etc
- Eficiență scăzută în cazul atacurilor “low and slow”
 - Advanced Persistent Threats (APT)
- Tendința este de integrare a funcției de IDS/IPS în cadrul firewall-urilor

Produce IDS/IPS

- **Network-based:**
 - Snort
 - Suricata
 - Zeek (Bro)
 - Cisco Firepower
 - Palo Alto Networks IDS/IPS

- **Host-based:**
 - OSSEC
 - McAfee Intrusion Prevention System
 - Symantec Critical System Protection



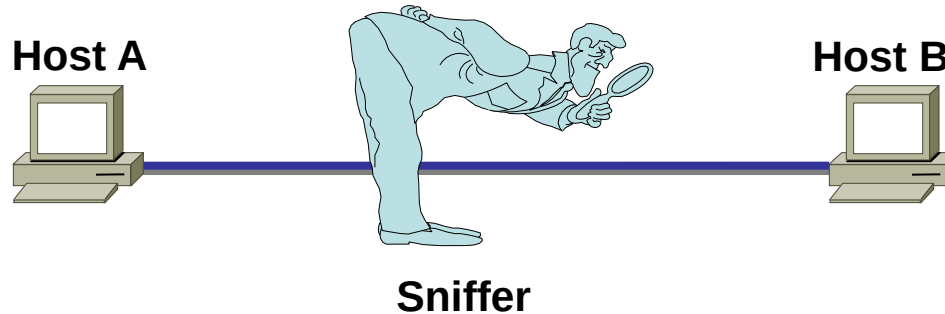
3. Securitatea la nivelul rețelei locale (LAN)



De ce securitate la nivel LAN?

- 90% din porturile de rețea ale companiilor sunt deschise
- În mod obișnuit, orice laptop se poate conecta pe unul din aceste porturi și obține acces în rețea
- 70% din atacuri vin din interiorul organizației
- Atacuri specifice:
 - Sniffing
 - DHCP Starvation
 - Rogue DHCP Server
 - ARP Poisoning
 - ...

Sniffers



- Un sniffer de pachete este un sistem a cărui placă de rețea operează în modul promiscuous și care captează pachetele transmise în rețea
- Captarea pachetelor se face în timp real
- Necesită privilegii de superuser pentru a fi rulat
- Folosit pentru:
 - diagnosticarea problemelor (inclusiv cele de securitate) apărute în cadrul rețelelor – analizor de rețea
 - jurnalizarea traficului din rețea în vederea analizei ulterioare în cazul apariției unui incident de securitate – forensics analysis
 - interceptarea parolelor sau a altor informații confidențiale – hacking tool

Sniffers - Produse

- tcpdump (<http://www.tcpdump.org>)
 - platforme Unix
 - utilitar în linie de comandă
- Wireshark (<http://www.wireshark.org/>)
 - interfață grafică
 - disponibil pe aproape toate tipurile de platforme
 - tshark (utilitar în linie de comandă)
- ngrep (<http://ngrep.sourceforge.net/>)
 - regular expressions pentru căutarea în pachete
- Librari (API) pentru captarea de pachete (pcap):
 - libpcap / WinPcap (C/C++)
 - JpCap (Java)

tcpdump

- **Sintaxa:**

tcpdump [options] [filter expression]

- **Optiuni uzuale:**

- i <n>: specifica interfata pe care se face captarea pachetelor
- a: activeaza conversia adreselor IP in nume
- n: dezactiveaza conversia adreselor IP in nume
- s 0: analizeaza intregul pachet
- A: tipareste continutul pachetului in format ASCII
- w <filename>: salveaza pachetele captate intr-un fisier
- r <filename>: citeste pachetele dintr-un fisier

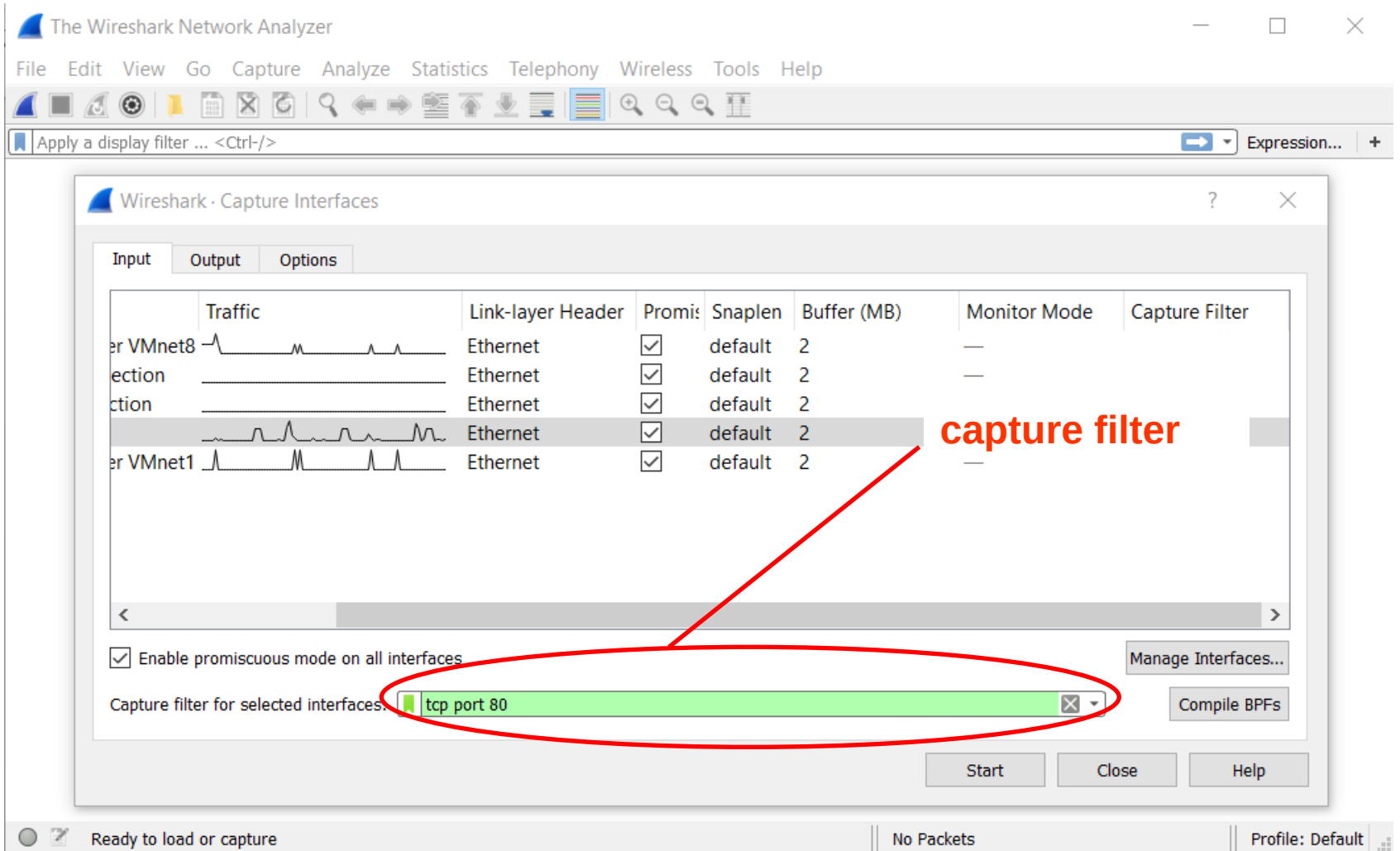
tcpdump (cont.)

- Filtrare dupa protocol
 - “icmp”
 - “udp”
 - “tcp”
- Filtrare dupa adresa
 - “dst host <name/IP>”
 - “src host <name/IP>”
 - “host <name/IP>”
- Filtrare dupa port
 - “dst port <number>”
 - “src port <number>”
 - “port <number>”
- Combinarea filtrelor
 - *and* (&&)
 - *or* (||)
 - *not* (!)

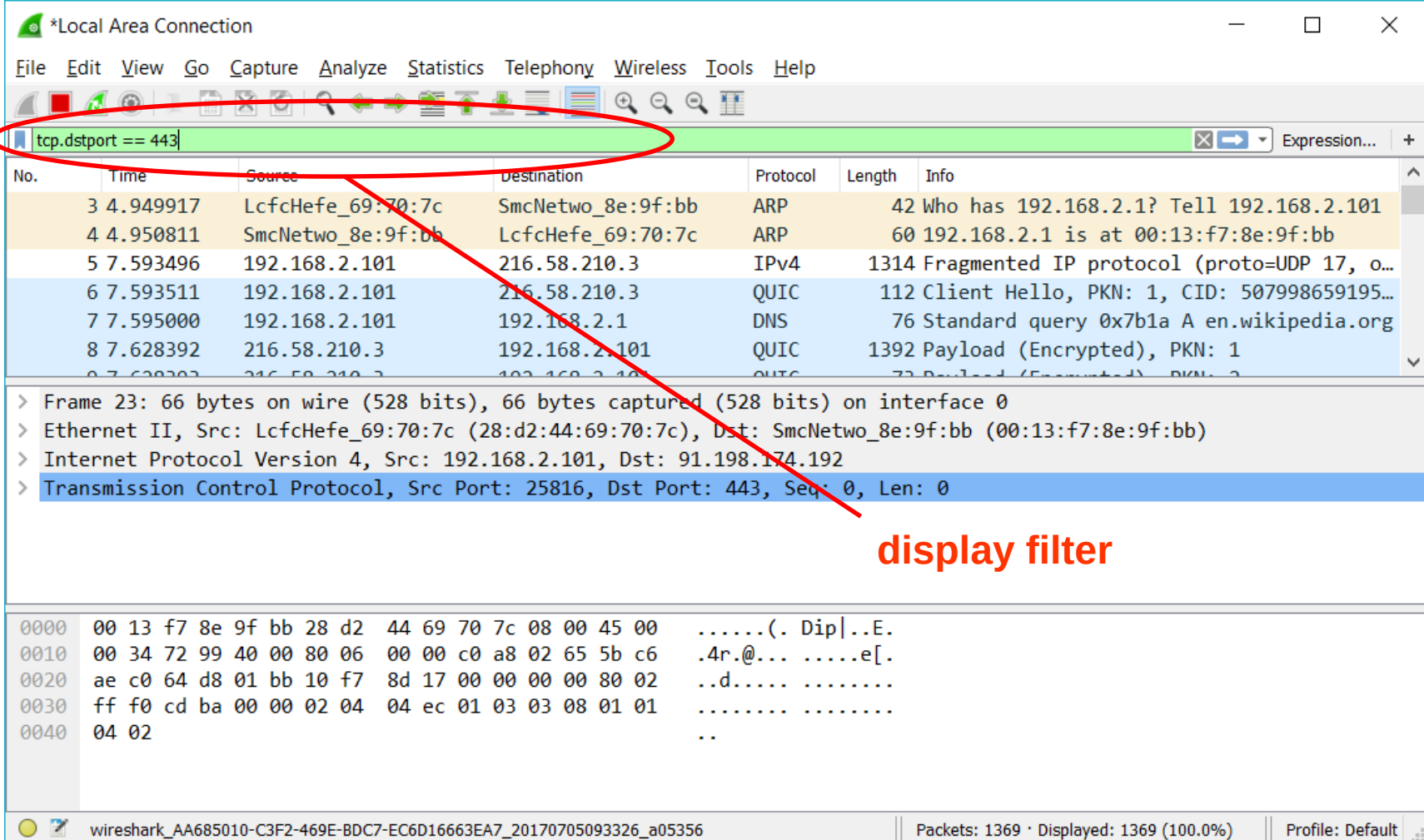
tcpdump (cont.)

- **Afişare interfețe de rețea**
tcpdump -D
- **Captare trafic de rețea de la o anumită interfață**
tcpdump -i eth0
- **Captare trafic după adresa IP**
tcpdump host 192.160.0.10
- **Captare trafic după port**
tcpdump port 22
- **Captare trafic după protocol**
tcpdump icmp
tcpdump tcp port 443
- **Afişare pachete captate în ASCII / HEX**
tcpdump -A tcp port 80
tcpdump -X tcp port 80
- **Dezactivare conversie adrese în nume**
tcpdump -n
- **Salvare pachete captate într-un fișier**
tcpdump port 80 -w capture_file
- **Citire pachete din fișier**
tcpdump -r capture_file

Wireshark



Wireshark (cont.)



The image shows the Wireshark network protocol analyzer interface. At the top, the title bar reads '*Local Area Connection'. Below it is a menu bar with options: File, Edit, View, Go, Capture, Analyze, Statistics, Telephony, Wireless, Tools, and Help. A toolbar with various icons is located below the menu bar. A red circle highlights the packet capture filter bar, which contains the text 'tcp.dstport == 443'. Below the filter bar is a table of captured packets. The table has columns: No., Time, Source, Destination, Protocol, Length, and Info. The first four packets are highlighted in yellow, and the next four are highlighted in blue. A red arrow points from the filter bar to the 'Destination' column of the fourth packet (No. 7). Below the packet list is a detailed view of the selected packet (No. 7), showing its structure: Ethernet II, Internet Protocol Version 4, and Transmission Control Protocol. The bottom of the interface shows a hex dump of the packet data.

No.	Time	Source	Destination	Protocol	Length	Info
3	4.949917	LcfcHefe_69:70:7c	SmcNetwo_8e:9f:bb	ARP	42	Who has 192.168.2.1? Tell 192.168.2.101
4	4.950811	SmcNetwo_8e:9f:bb	LcfcHefe_69:70:7c	ARP	60	192.168.2.1 is at 00:13:f7:8e:9f:bb
5	7.593496	192.168.2.101	216.58.210.3	IPv4	1314	Fragmented IP protocol (proto=UDP 17, o...
6	7.593511	192.168.2.101	216.58.210.3	QUIC	112	Client Hello, PKN: 1, CID: 507998659195...
7	7.595000	192.168.2.101	192.168.2.1	DNS	76	Standard query 0x7b1a A en.wikipedia.org
8	7.628392	216.58.210.3	192.168.2.101	QUIC	1392	Payload (Encrypted), PKN: 1

display filter

0000 00 13 f7 8e 9f bb 28 d2 44 69 70 7c 08 00 45 00(. Dip|..E.
0010 00 34 72 99 40 00 80 06 00 00 c0 a8 02 65 5b c6 .4r.@... ..e[.
0020 ae c0 64 d8 01 bb 10 f7 8d 17 00 00 00 00 80 02 ..d.....
0030 ff f0 cd ba 00 00 02 04 04 ec 01 03 03 08 01 01
0040 04 02 ..

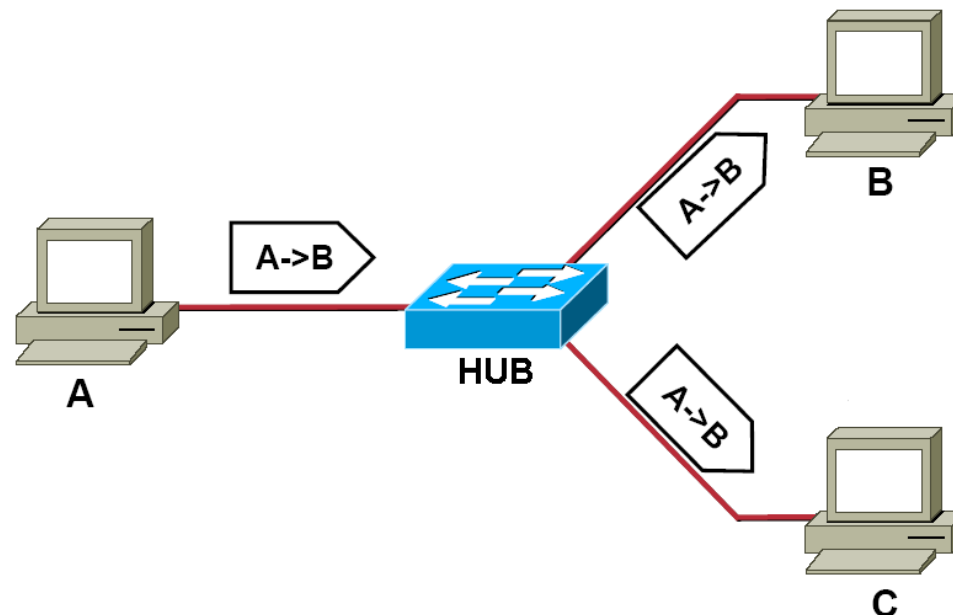
wireshark_AA685010-C3F2-469E-BDC7-EC6D16663EA7_20170705093326_a05356 | Packets: 1369 · Displayed: 1369 (100.0%) | Profile: Default

TShark

- **Terminal-based Wireshark**
- **Sintaxă similară cu tcpdump**
- **Suportă filtre de captare (BFP) și filtre de afișare**
 - # tshark -i any -w traffic.pcap**
 - # tshark -i eth0 -f "host 192.168.1.100 and port 80"**
 - # tshark -i eth0 -Y "tcp.port == 8080 and http.request"**

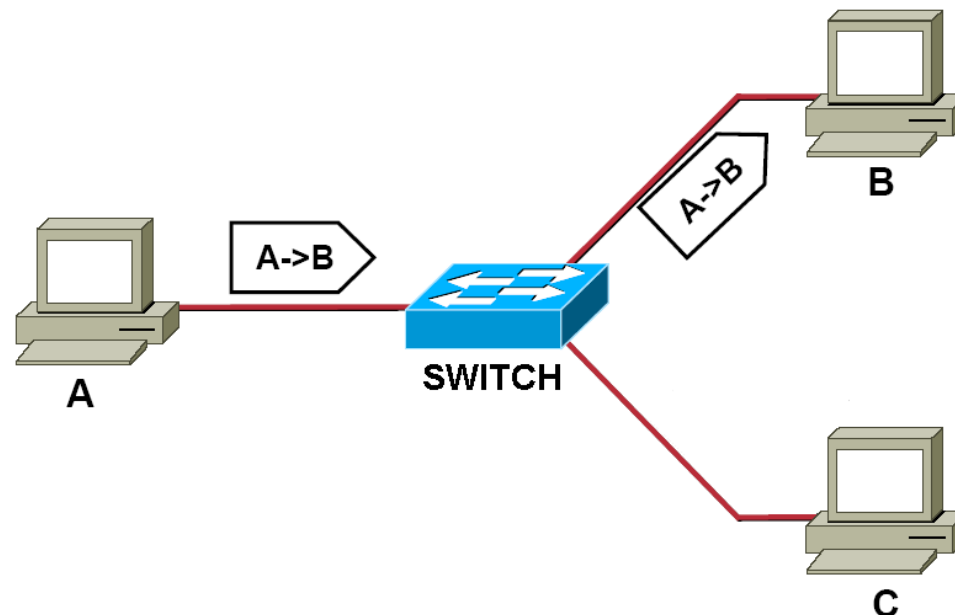
Sniffing pasiv

- Folosit pentru a intercepta traficul în rețele bazate pe HUB-uri
 - traficul de pe un port este forwardat către toate celelalte porturile
- Este suficient doar să se asculte pentru a capta toate pachetele din rețea
 - nu se intervine cu nimic asupra rețelei
 - atacul nu poate fi detectat



Sniffing activ

- Folosit pentru a intercepta traficul în rețele bazate pe SWITCH-uri
 - traficul de pe un port este forwardat numai către portul destinație corespunzător
- Pentru a putea capta pachetele din rețea trebuie să se intervină asupra rețelei
- Atacuri posibile
 - inundarea switch-ului (MAC Flooding)
 - furarea portului (Port Stealing)



Adrese MAC

48 Bit Hexadecimal Number Creates Unique Layer Two Address

1234.5678.9ABC

First 24 bits = Manufacture Code
Assigned by IEEE

0000.0cXX.XXXX

Second 24 bits = Specific Interface,
Assigned by Manufacture

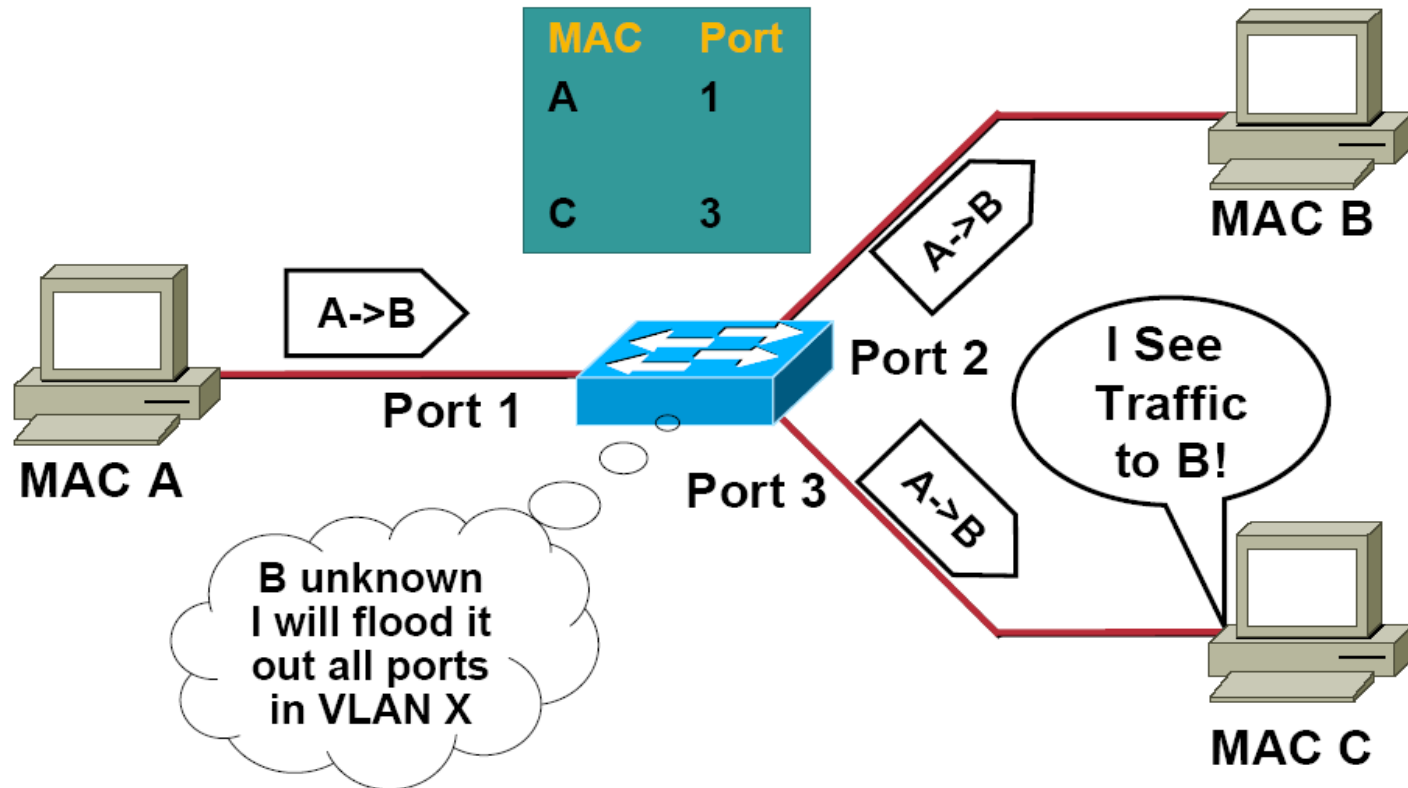
0000.0cXX.XXXX

All F's = Broadcast

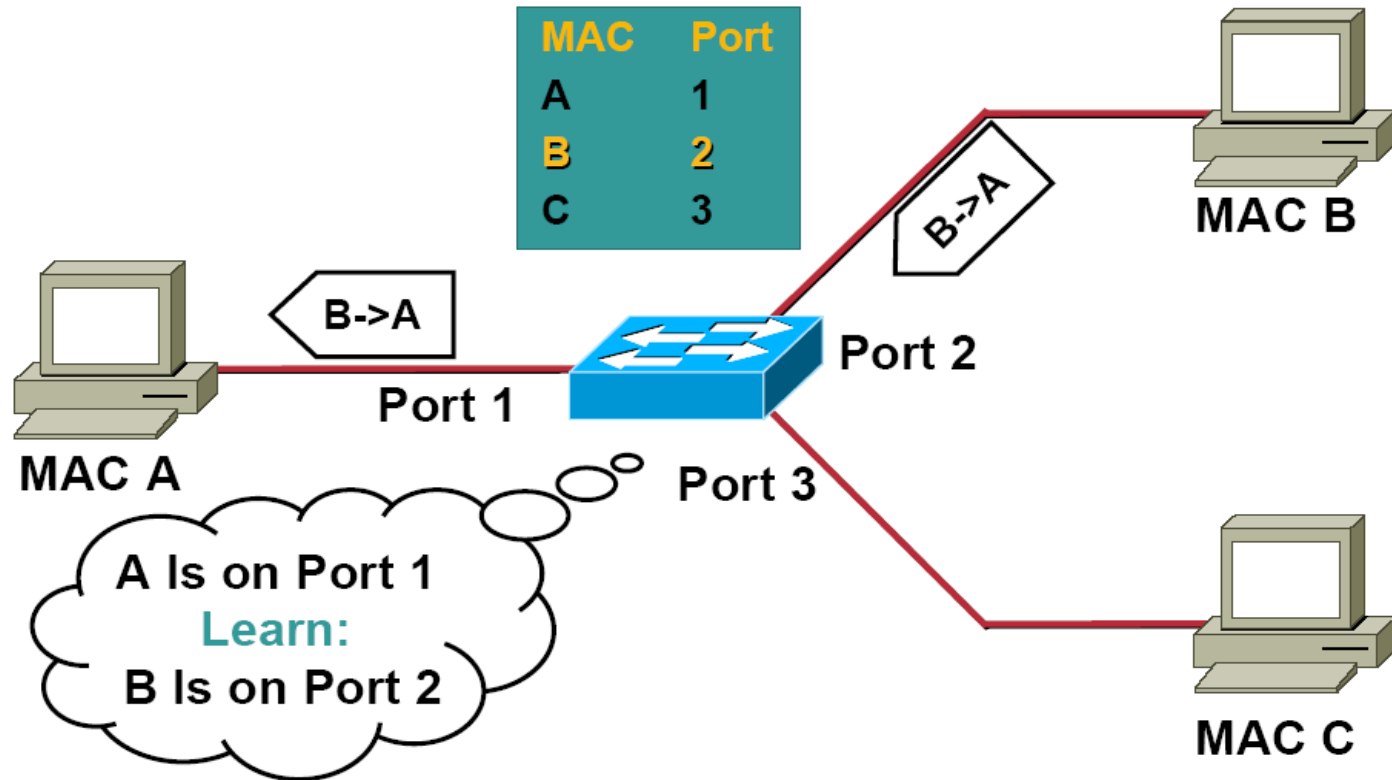
FFFF.FFFF.FFFF

- Pentru a-și îndeplini rolul și a optimiza distribuția traficului, switch-urile “învață” aceste adrese, memorandu-le într-o așa numită tabelă CAM (Content Addressable Memory)
- Tabela CAM a unui switch dispune de o zonă limitată de memorie (parametru important al unui switch)

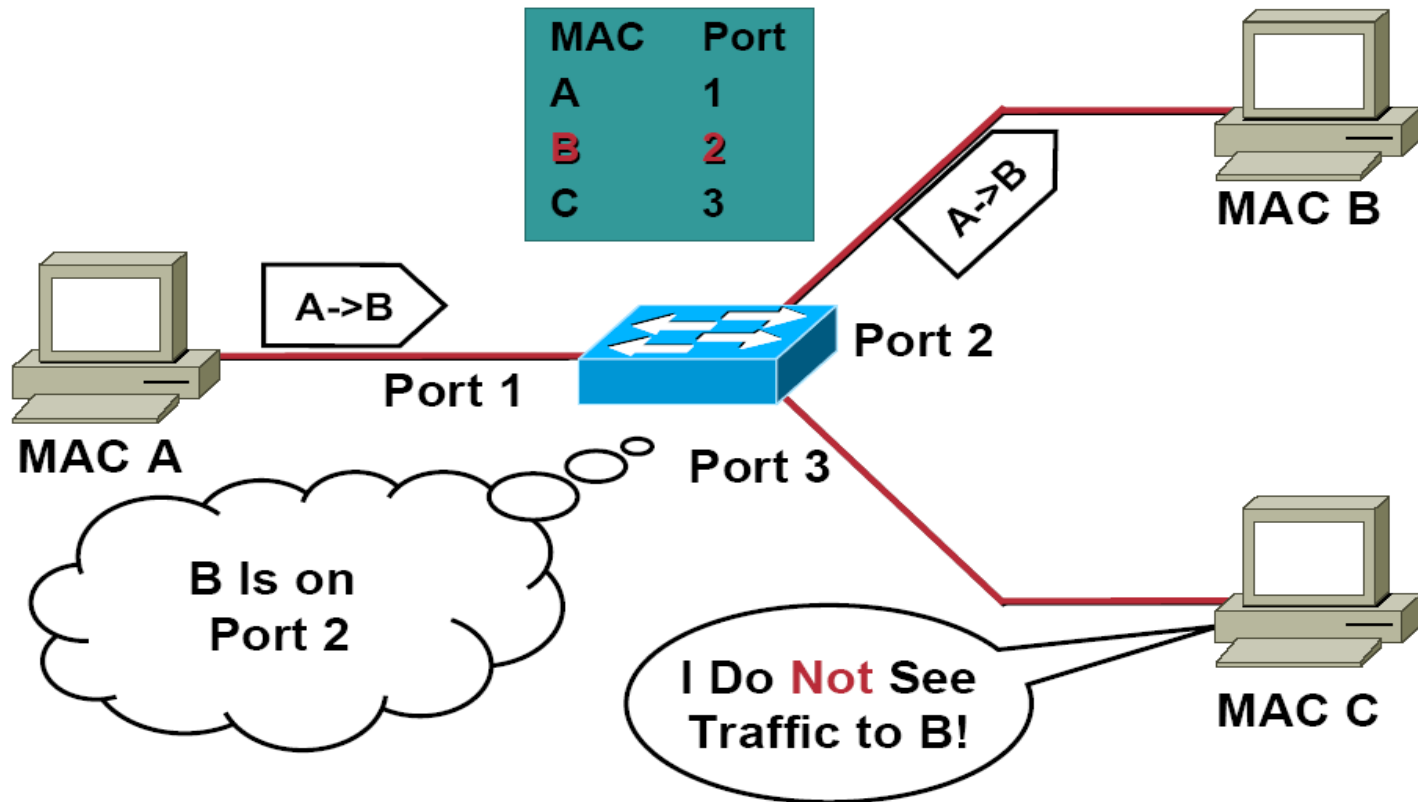
Funcționarea normală a unui switch



Funcționarea normală a unui switch (cont.)



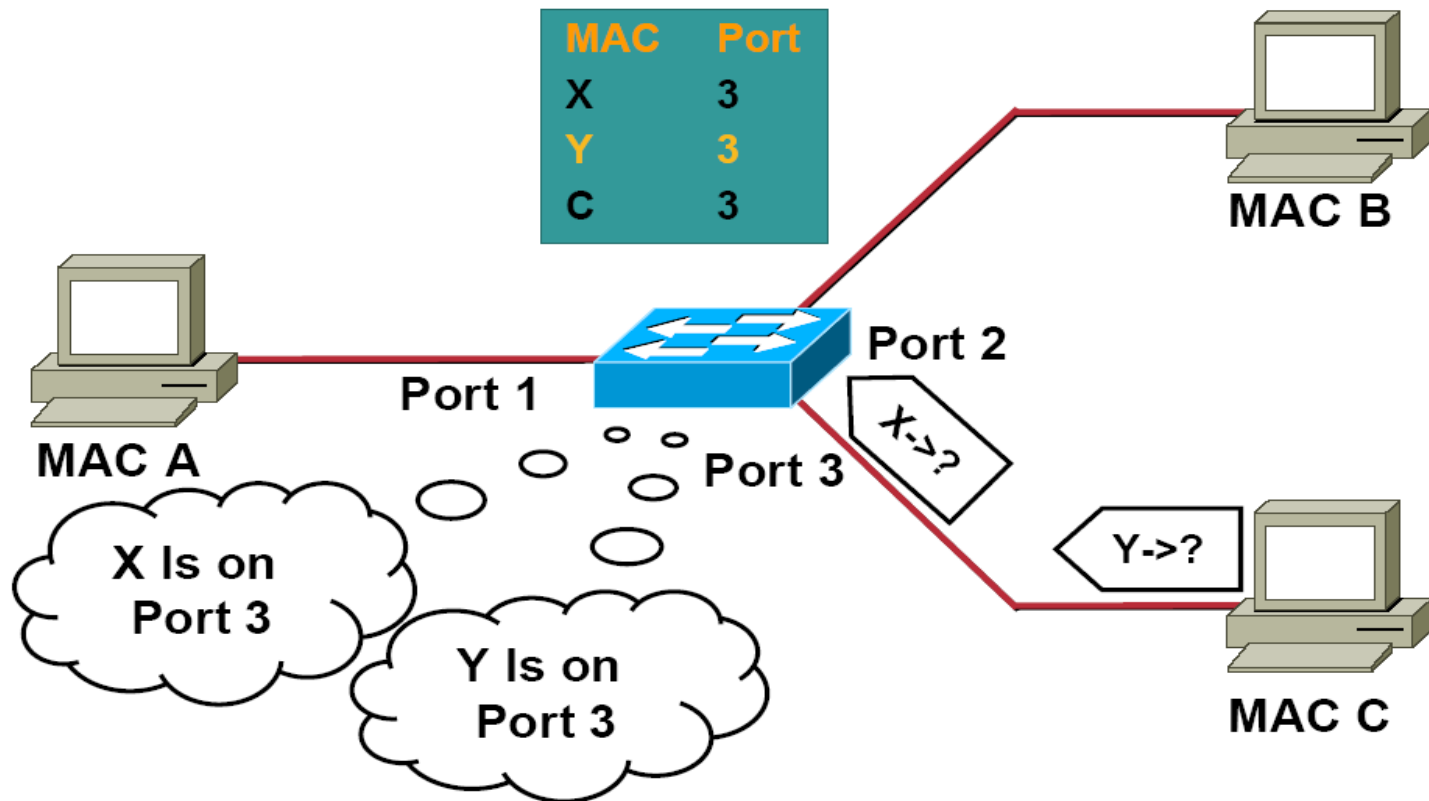
Funcționarea normală a unui switch (cont.)



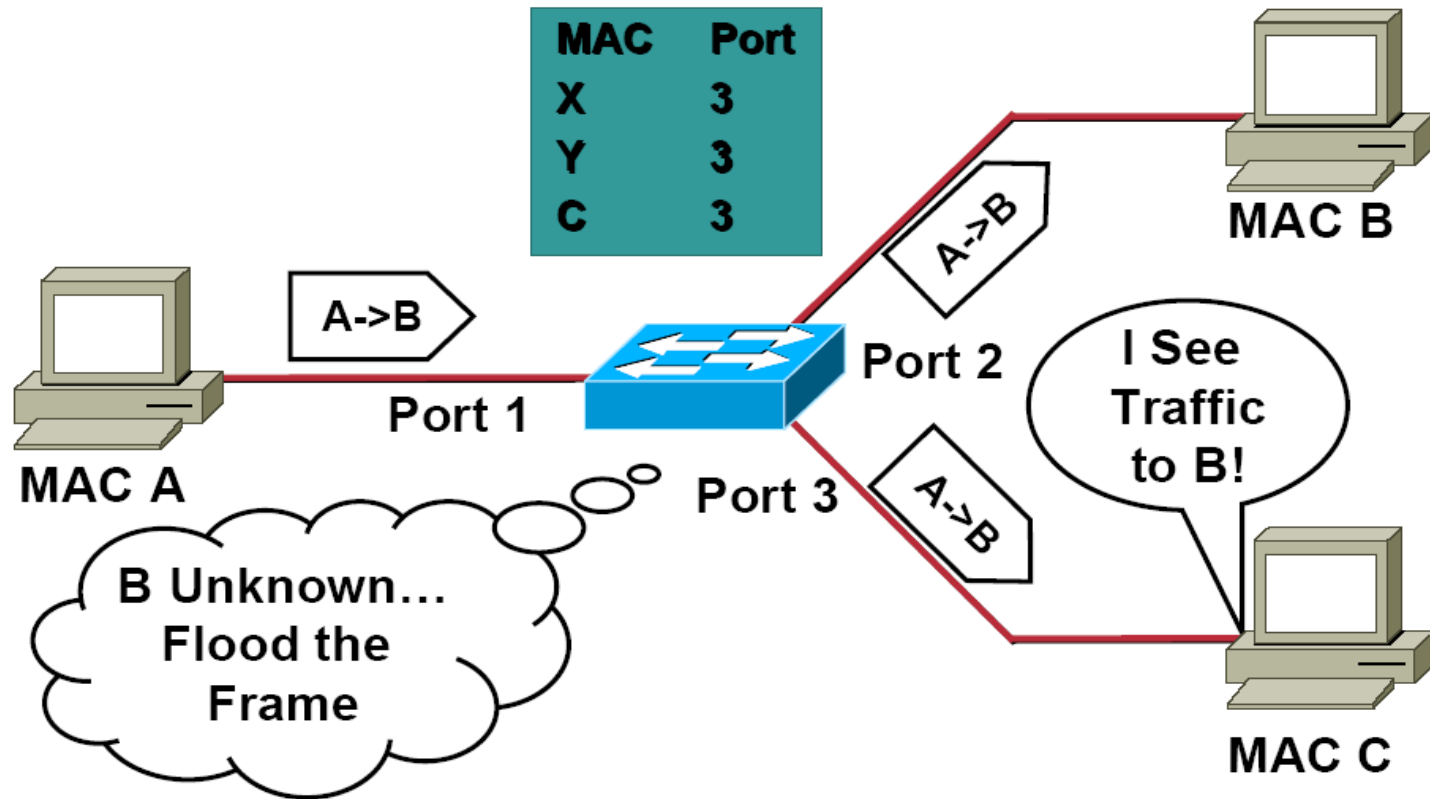
MAC Flooding

- Până în Mai 1999, atacul era considerat ca fiind posibil numai din punct de vedere teoretic
- În Mai 1999, Ian Vitek demonstrează printr-un program scris în Perl – *macof* – că atacul este fezabil
 - atacul se bazează pe capacitatea limitată a memoriei alocată tablei CAM dintr-un switch (valori uzuale: 32K, 64K, 128K)
- Programul a fost ulterior portat în C, sub numele de *dsniff* (<http://monkey.org/~dugsong/dsniff/>)
 - colecție de unelte pentru penetration testing
 - sniffing pasiv: dsniff, filesnarf, mailsnarf, msgsnarf, urlsnarf, webspay
 - sniffing activ: arpspoof, dnsspoof, macof
 - atacuri de tip monkey-in-the-middle: sshmitm, webmitm

MAC Flooding (cont.)



MAC Flooding (cont.)

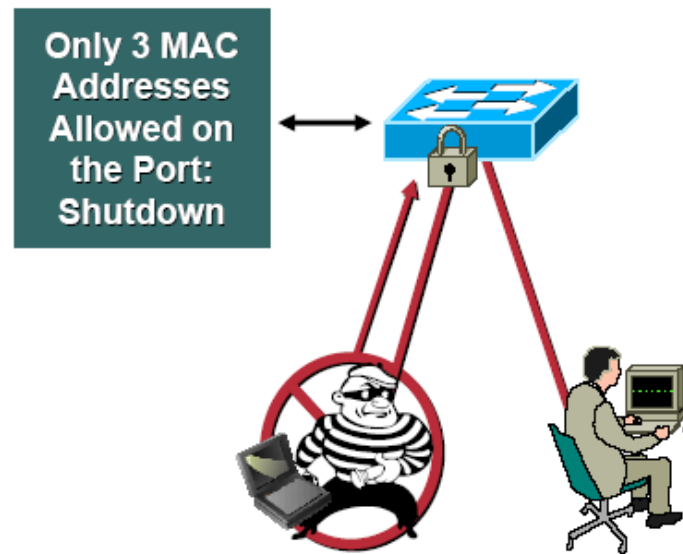
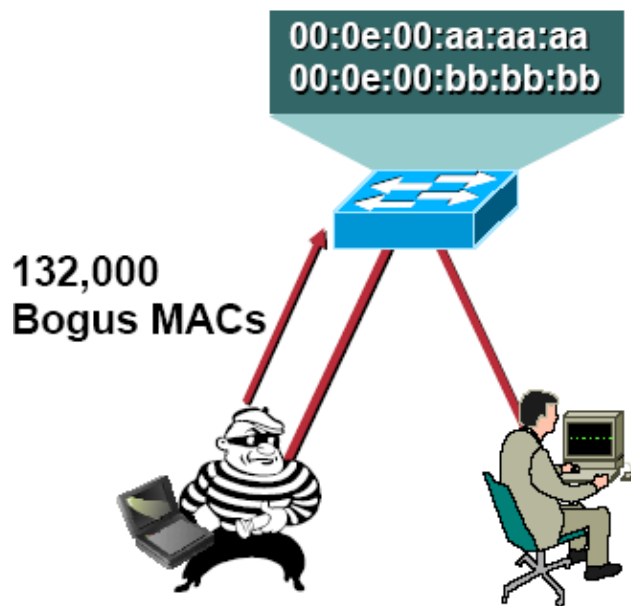


Port Stealing

- Switch-urile asociază adrese MAC cu porturi fizice de comunicație
 - maparea se realizează în urma examinării adresei MAC sursă a cadrelor recepționate
- Atacul de tip “port stealing” constă în inundarea rețelei cu cadre, având:
 - Adresa MAC Destinație egală cu adresa atacatorului
 - **Adresa MAC Sursă** egală cu adresa victimei (e.g., default gateway)
- Astfel, switch-ul va asocia adresa MAC a victimei cu portul la care se află conectat atacatorul
 - atacatorul va putea astfel intercepta toate cadrele având ca destinație adresa victimei
- Cum retransmitem cadrele înapoi către victimă?
 - atacatorul trimite request-uri ARP pentru a afla adresa IP a victimei
 - victima răspunde, switch-ul vede cadrul și actualizează numărul de port
 - atacatorul trimite cadrele interceptate anterior către victimă
- Unele:
 - Ettercap (<http://ettercap.sourceforge.net/>)

MAC Flooding / Port Stealing - Contramăsuri

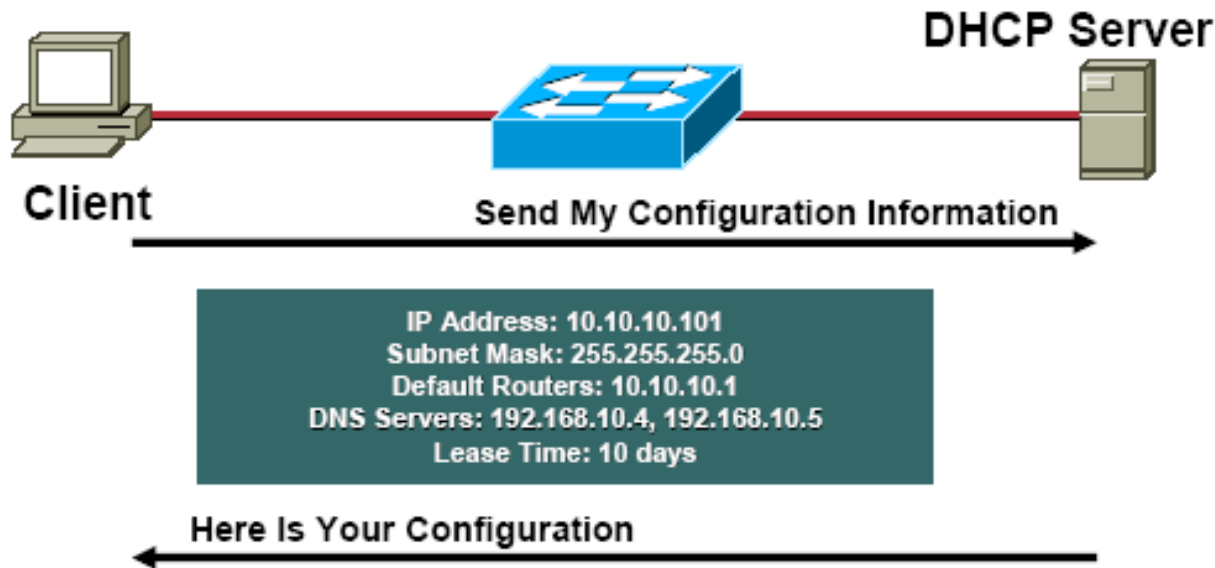
- Limitarea numărului maxim de adrese MAC învățate pe un port de către switch



Mecanismul "Port Security"

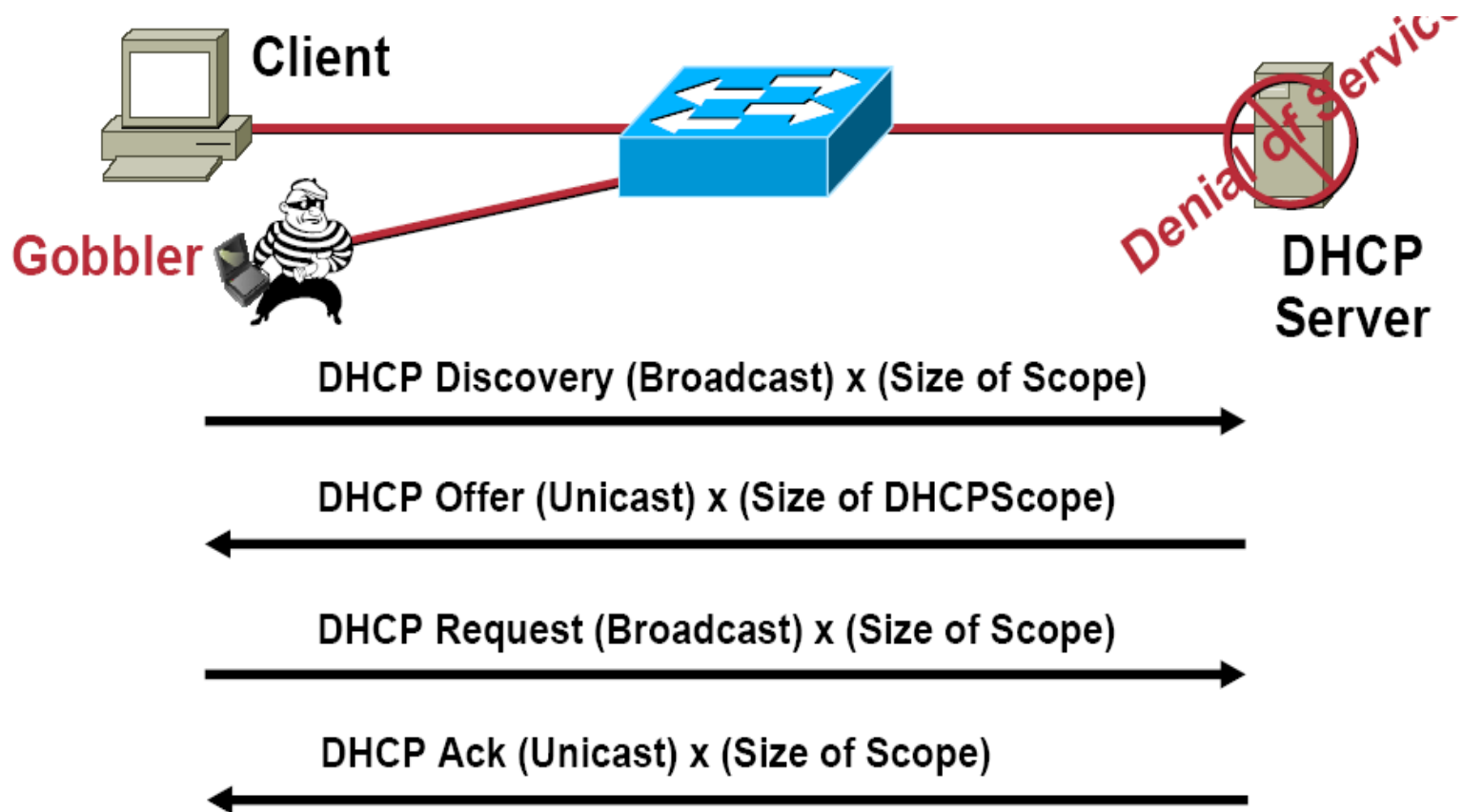
- limitarea numărului de adrese MAC permise pe un port, blocarea portului în caz de depășire, transmiterea unei trape SNMP

Protocolul DHCP



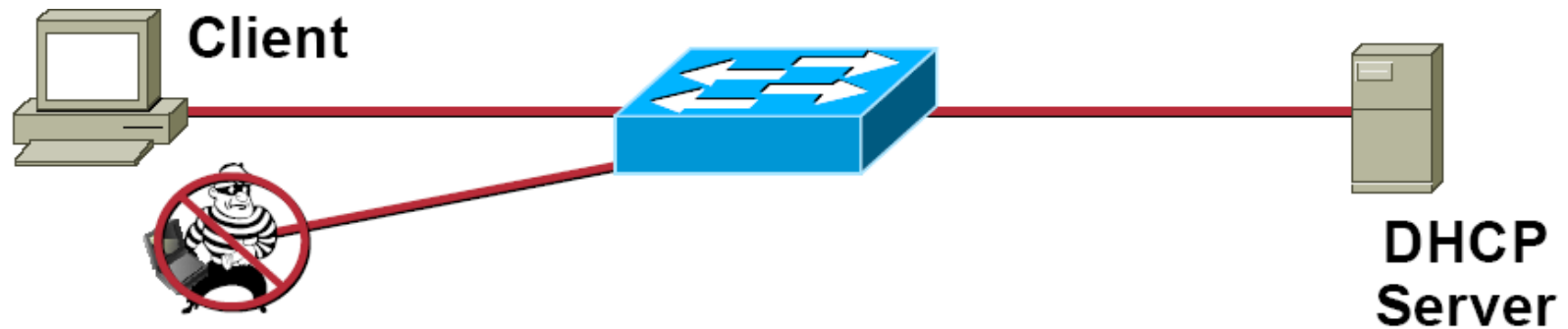
- Administratorul configurează un spațiu de adrese IP alocabil dinamic
- Server-ul alocă dinamic o adresa IP, la cerere
- Adresa este alocată pentru o perioadă de timp
- În campul "Options" sunt furnizate informații suplimentare

Atacul de tip DHCP Starvation



- Atacatorul încearcă să închirieze toate adresele IP disponibile prin DHCP
- Atac de tip Denial of Service (DoS)

DHCP Starvation - Contramăsuri



- De fiecare dată când atacatorul face o cerere DHCP utilizează o adresă MAC diferită
- Mecanismul “Port Security” restricționează numărul maxim de adrese MAC acceptate pe un port
- Atacatorul nu va putea obține un număr de adrese IP mai mare decât numărul maxim de adrese MAC acceptate pe acel port

Atacul de tip Rogue DHCP Server



DHCP Discovery (Broadcast)



2 DHCP Offers (Unicast) (1 from Rogue, 1 genuine)



DHCP Request (Broadcast) to 1st offer



DHCP Ack (Unicast) from Rogue Sever



Atacul de tip Rogue DHCP Server (cont.)

- Ce poate să facă atacatorul atunci când devine server DHCP?

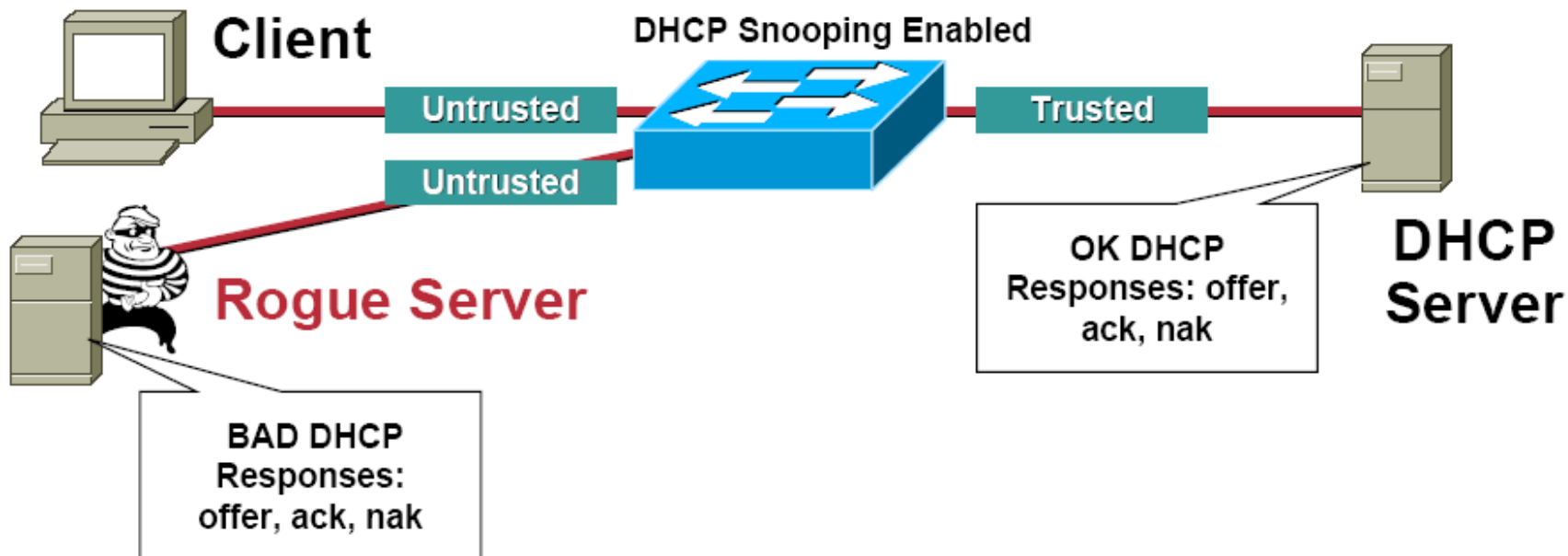
```
IP Address: 10.10.10.101
Subnet Mask: 255.255.255.0
Default Routers: 10.10.10.1
DNS Servers: 192.168.10.4, 192.168.10.5
Lease Time: 10 days
```

Here is Your Configuration



- Furnizează informații incorecte, cum ar fi:
 - Default Gateway – Atacatorul este gateway
 - DNS Server – Atacatorul este server DNS
 - Adresa IP – Alocată incorect (atac de tip DoS)

Rogue DHCP Server - Contramăsuri

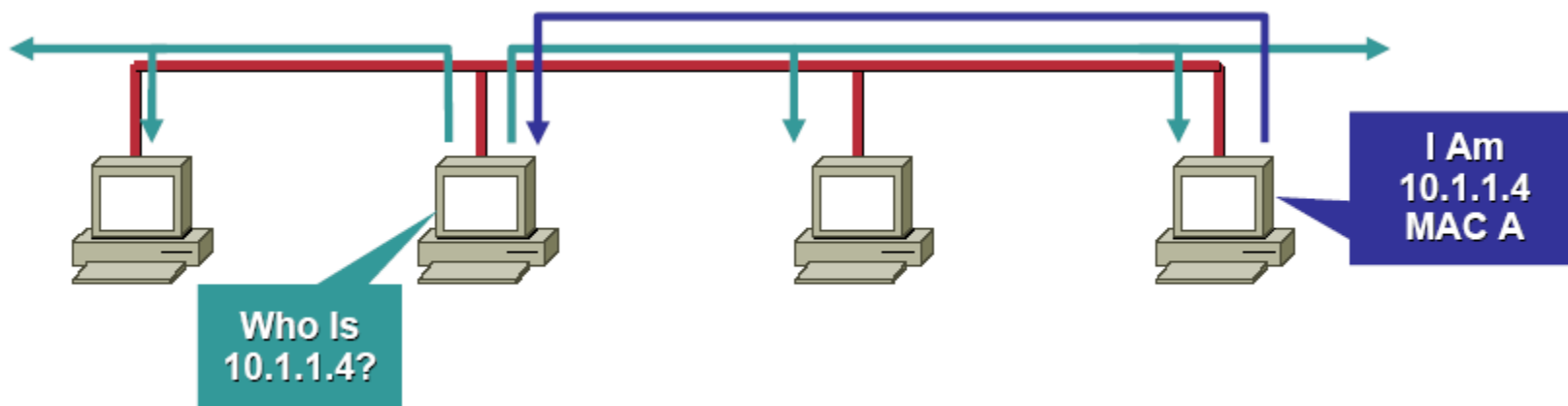


■ Mecanismul "DHCP Snooping"

- La activarea mecanismului, implicit, toate porturile unui switch sunt în starea "Untrusted"
- Se va configura starea "Trust" pe portul pe care se afla server-ul DHCP (eventual, pe portul de "uplink", dacă server-ul nu se află pe același switch)
- Switch-ul blochează mesajele "DHCP Reply" ce vin de pe porturile marcate "Untrusted"

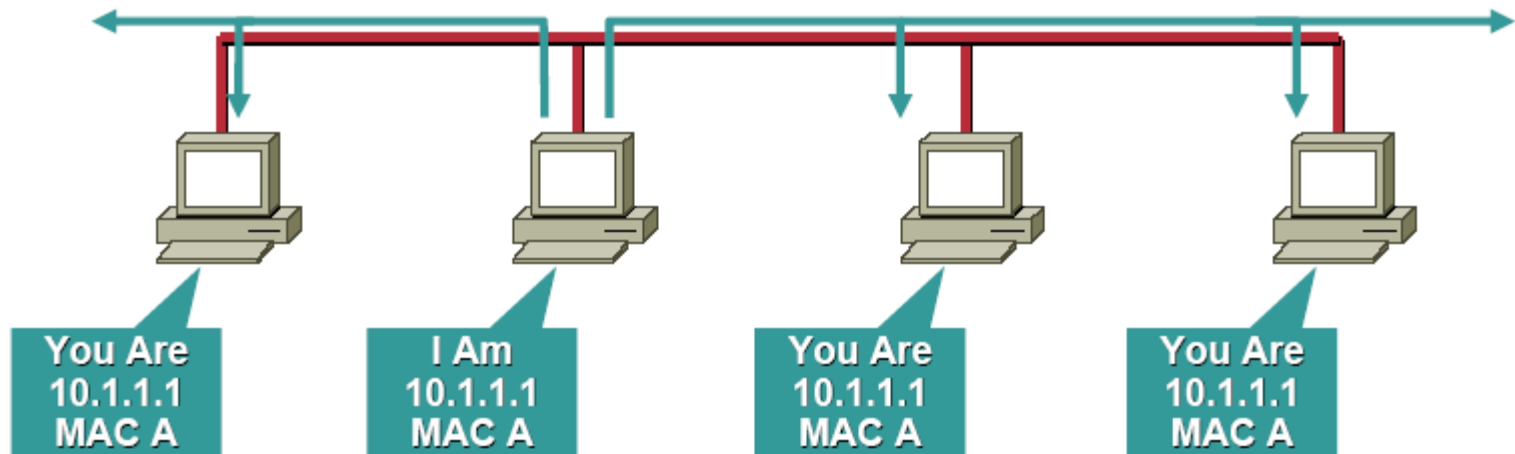
Protocolul ARP

- Înainte ca o stație să poată comunica cu altă stație din rețea, aceasta va transmite o cerere ARP, cu scopul de a afla adresa fizică (MAC) a stației destinație
- Cererea ARP este trimisă sub forma unui broadcast (la nivel 2)
- Toate stațiile din aceeași rețea vor recepționa și procesa cererea ARP; de răspuns, va răspunde doar stația care își va recunoaște adresa IP în conținutul cererii
- Răspunsurile ARP sunt menținute de kernel într-o tabelă (așa numitul “*cache ARP*”)



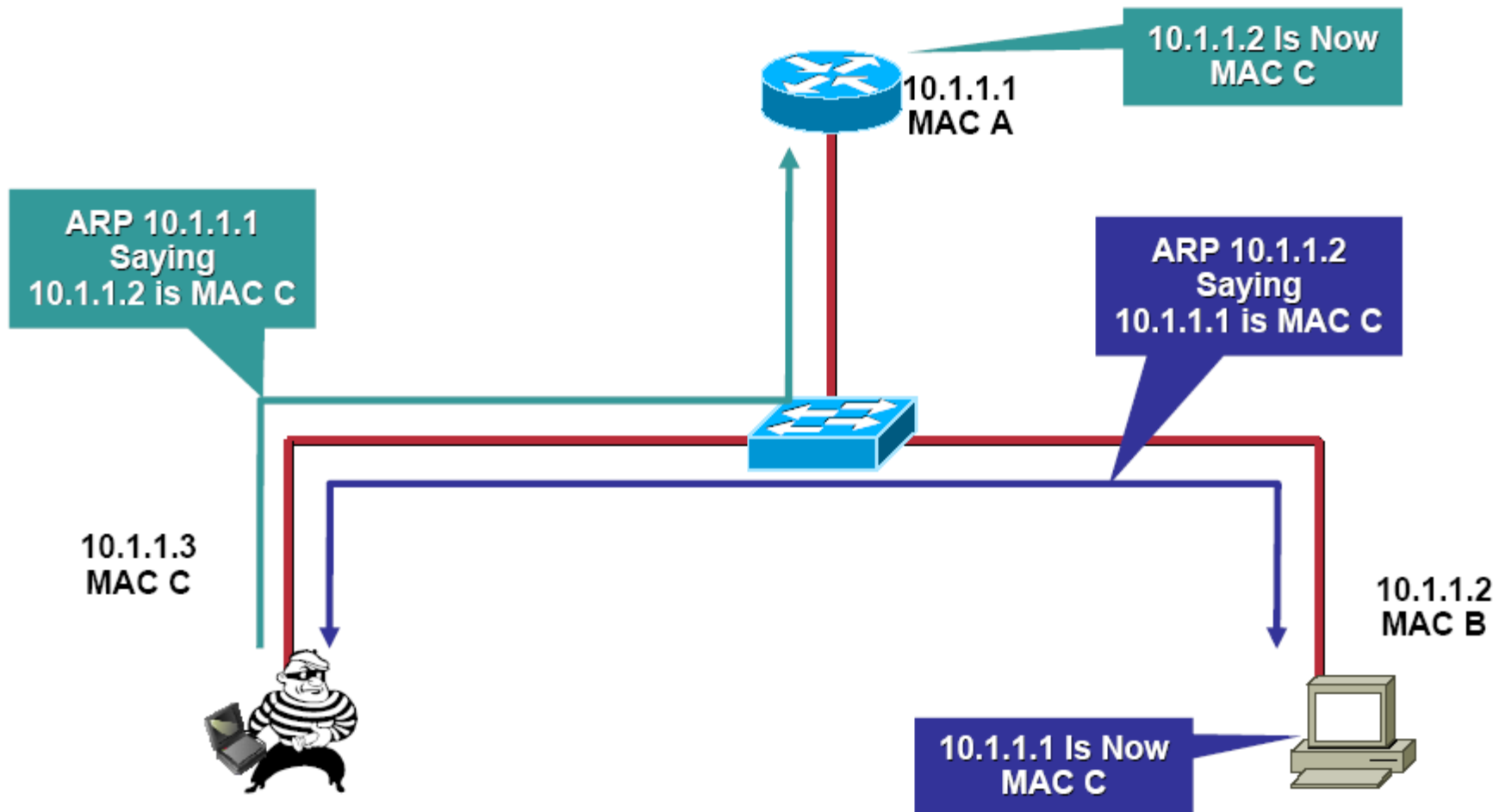
Protocolul ARP (cont.)

- În conformitate cu specificațiile protocolului ARP, unei stații îi este permis să transmită un răspuns ARP nesolicitat; celelalte stații din rețea vor memora această informație în cache-ul ARP propriu
- În acest mod, oricine poate pretinde că este proprietarul unei adrese IP/MAC
- Atacurile de tip “ARP Poisoning” folosesc această tehnică pentru redirectionarea traficului



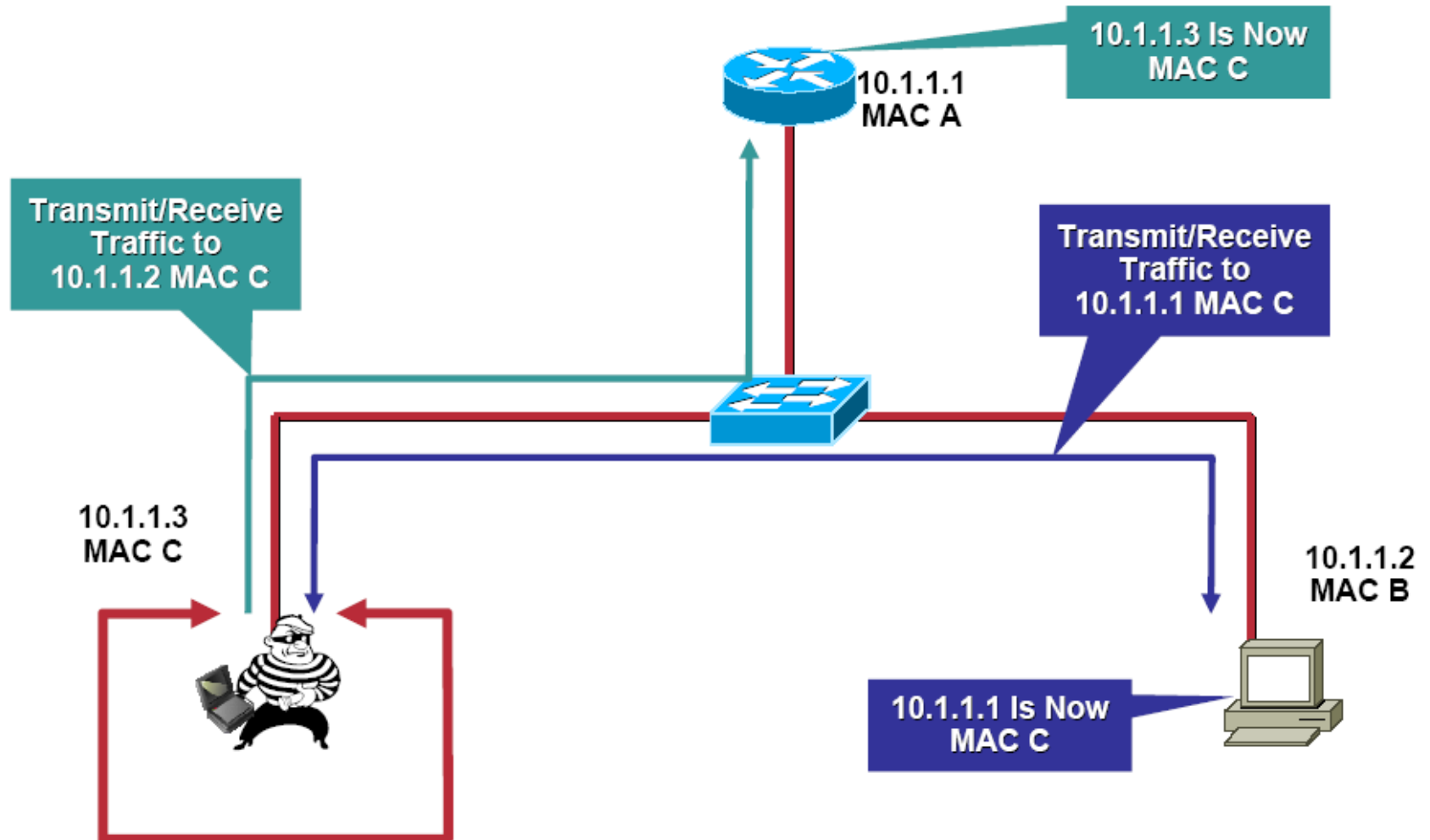
Atacul de tip ARP Poisoning

- **Atacatorul modifică tabelele ARP ale ruterului și PC-ului**



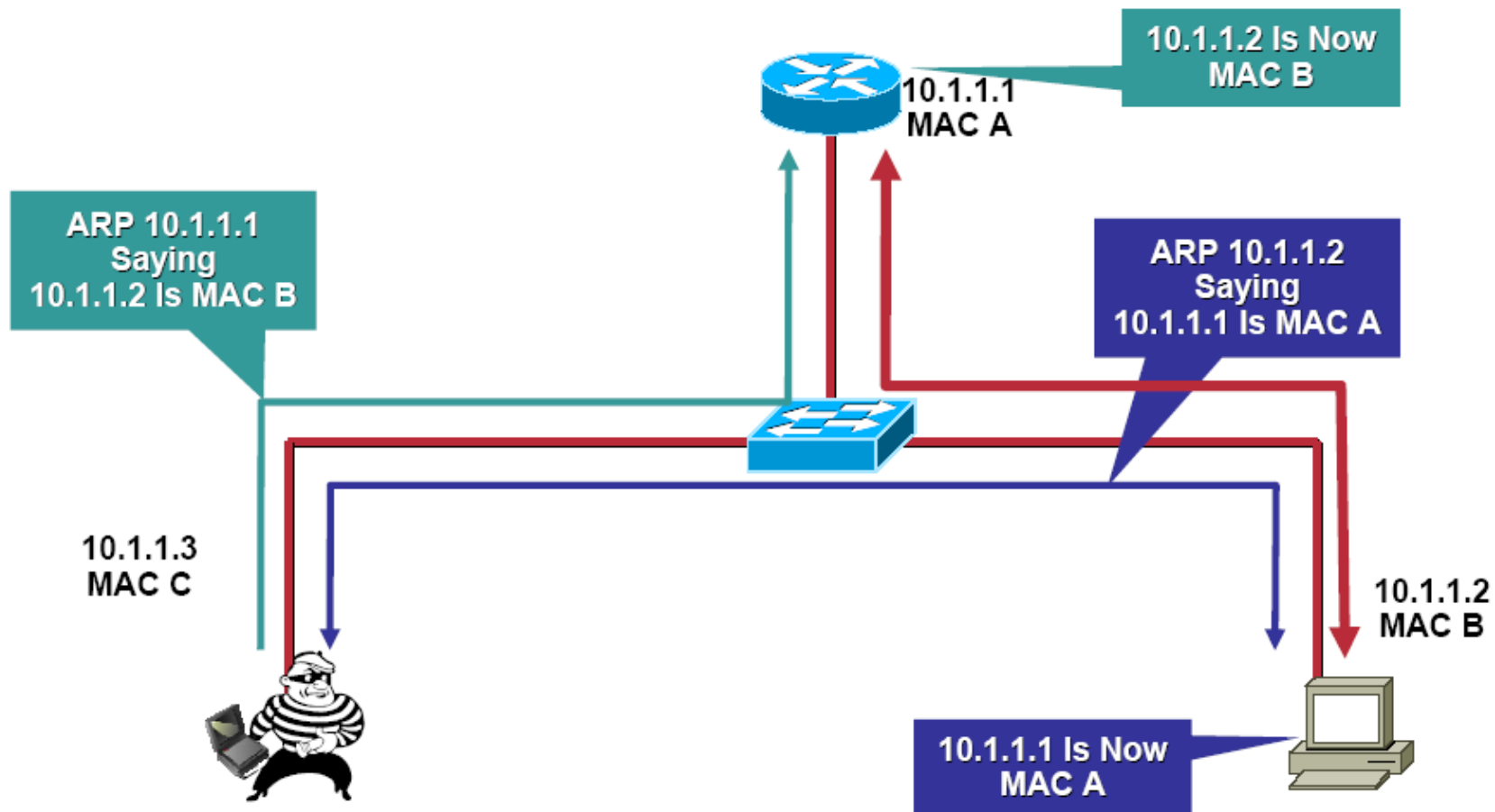
Atacul de tip ARP Poisoning (cont.)

- Tot traficul este astfel interceptat



Atacul de tip ARP Poisoning (cont.)

- În final, atacatorul corectează tabelele ARP
- Traficul revine la normal



ARP Poisoning - Unelte

- dsniff (<http://monkey.org/~dugsong/dsniff/>)
- Ettercap (<http://ettercap.sourceforge.net/>)
- Cain & Abel (<http://www.oxid.it/>)
- arpoison (<http://www.arpoison.net/>)

ARP Poisoning - Contramăsuri

- Crearea de intrări statice în tabelele ARP de pe stații
- Monitorizare rețea: arpwatch
- Dynamic ARP Inspection (Cisco)
- Secure-ARP (autentificare folosind certificate digitale)



4. Securitatea rețelelor wireless



Wireless LAN

- **Wireless LAN (WLAN) = grup de noduri ce comunică între ele prin legături radio**
- **Tehnologie disponibilă începând cu anii '90**
 - soluții proprietare (nestandard) ce operau în banda de 900 MHz și asigurau o rată de transfer de aproximativ 1 Mbps;
 - în 1992 apar primele produse ce lucrau în banda de 2.4 GHz și asigurau o rată de transfer îmbunătățită;
 - în 1997, IEEE ratifică primul standard pentru WLAN (IEEE 802.11)
- **Wi-Fi Alliance**
 - promovarea tehnologiei Wi-Fi și certificarea produselor



Standarde WLAN

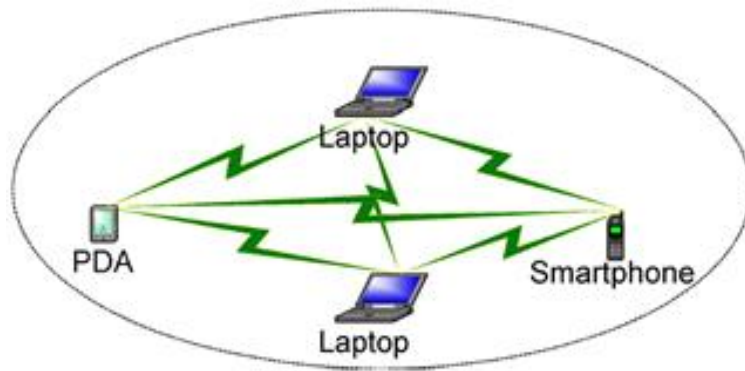
Standard	Frequency	Maximum Speed	Backwards compatibility
802.11	2.4 GHz	2 Mbps	-
802.11a	5 GHz	54 Mbps	-
802.11b	2.4 GHz	11 Mbps	-
802.11g	2.4 GHz	54 Mbps	802.11b
802.11n	2.4 and 5 GHz	600 Mbps	802.11a/b/g
802.11ac	5 GHz	1300 Mbps	802.11a/n
802.11ad	2.4 GHz, 5 GHz and 60 GHz	7 Gbps	802.11a/b/g/n/ac

- **Wired Equivalent Privacy (WEP)**
 - securitate limitată
- **Wi-Fi Protected Access (WPA)**
 - elaborat de Wi-Fi Alliance
- **Amendamentul IEEE 802.11i**
 - Robust Security Network (RSN) / WPA2

Arhitectura WLAN

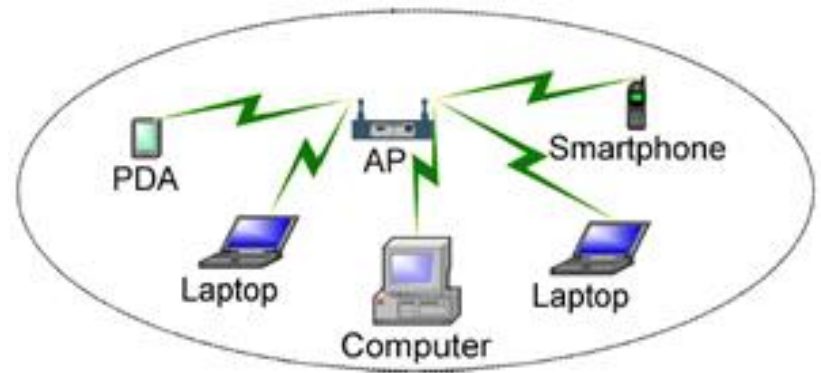
- **Elemente componente:**
 - stații (STA)
 - PC, laptop, PDA, telefon mobil, etc
 - Access Point (AP)
 - asigură interconectarea stațiilor
- **Configurații:**
 - ad hoc mode
 - infrastructure
- **Terminologie specifică:**
 - SSID / ESSID = numele rețelei WLAN
 - BSSID = adresa MAC a AP
 - channel = canalul de comunicație (1-12)
- **Wireless sniffing**
 - "monitor" mode ("promiscuous" mode)

Ad hoc vs. infrastructure mode



Ad hoc mode:

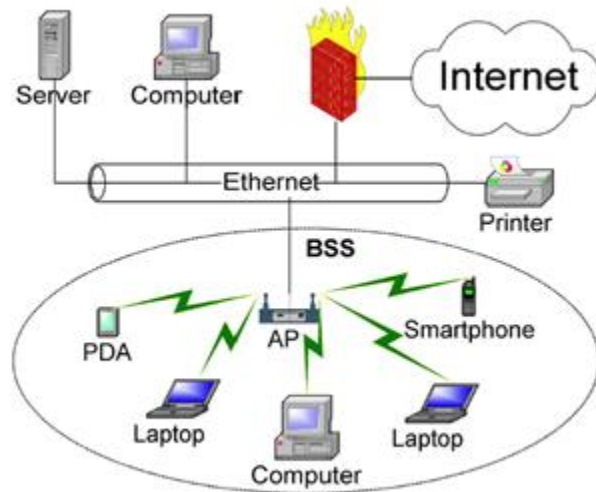
- stațiile comunică direct între ele



Infrastructure mode:

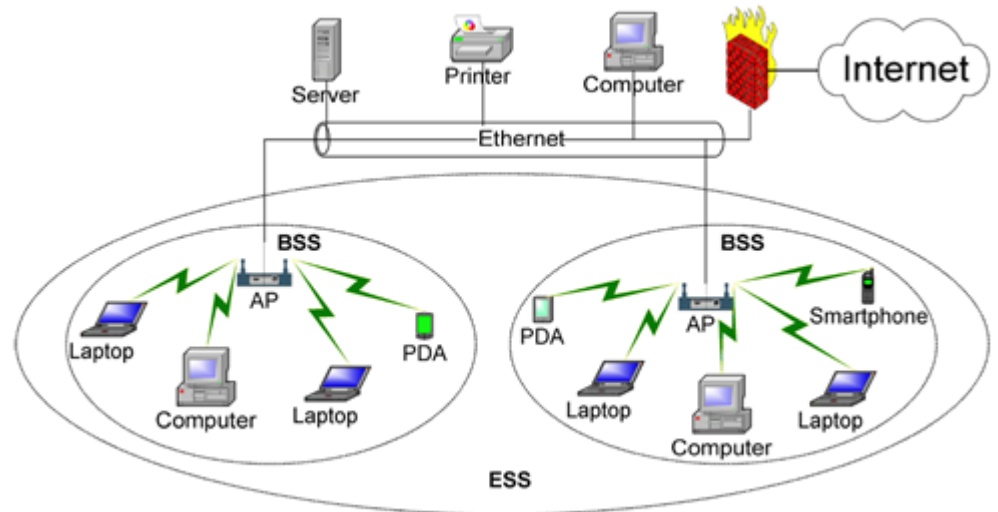
- comunicația între stații se realizează prin intermediul AP (releu)

BSS vs. ESS



Basic Service Set (BSS):

- o singura celula WLAN
- un AP + stațiile asociate

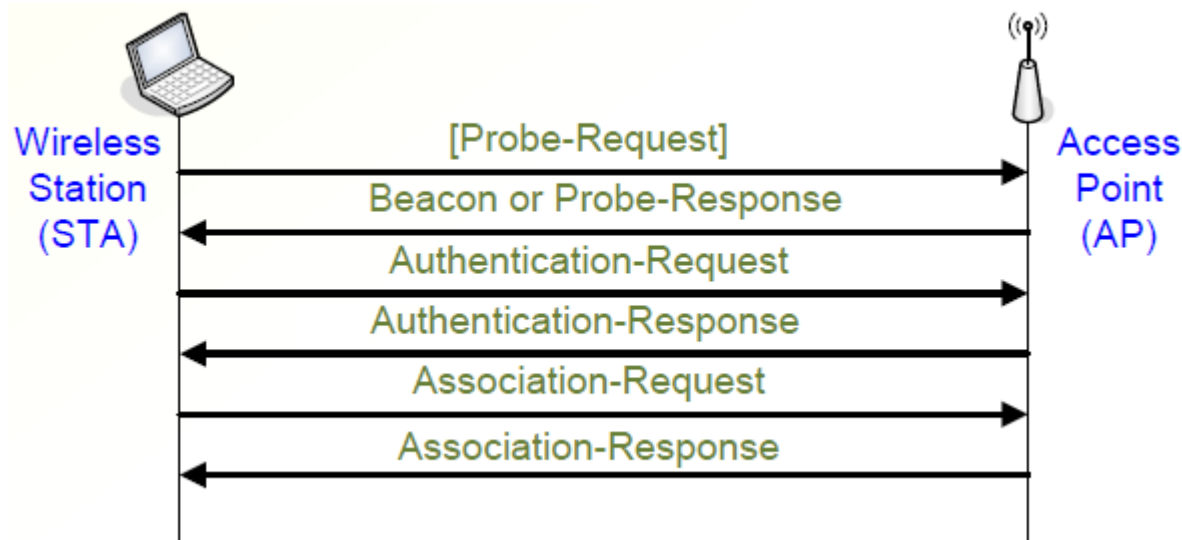


Extended Service Set (ESS):

- mai multe celule WLAN
- toate AP-urile au același SSID
- un singur VLAN

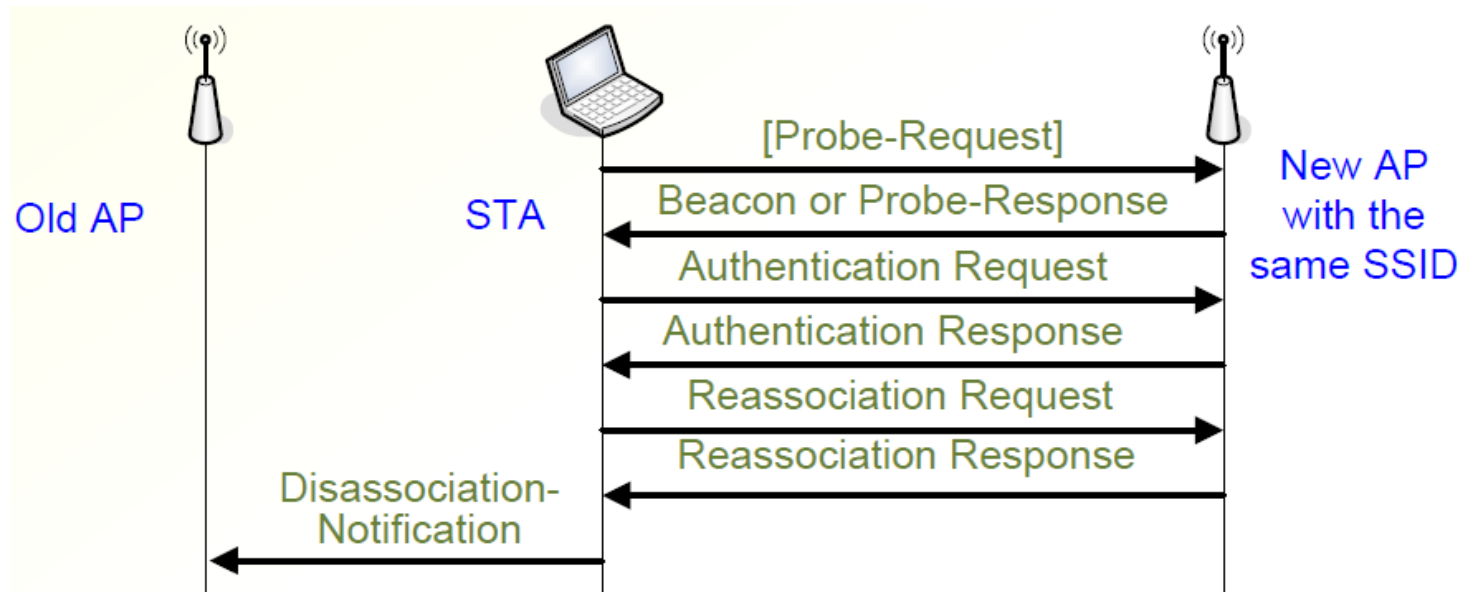
Conectarea la o rețea wireless

- AP-ul transmite beacons frames la fiecare 50-100 ms, pentru a-și anunța prezența
 - beacons frames conțin SSID (acest lucru poate fi dezactivat)
- Stațiile trebuie să specifice SSID-ul către AP în cererea de autentificare
- Open System Authentication



Conectarea la o rețea wireless (cont.)

- Stațiile aleg AP-ul funcție de puterea și calitatea semnalului
- O stație se poate reasocia automat cu un alt AP din ESS
- Migrarea între AP este transparentă din punct de vedere al nivelului rețea (IP)



Atacuri specifice WLAN

- Interceptarea traficului
- Spargerea cheilor WEP
- Spargerea cheilor WPA / WPA2
- Aflare PIN WPS
- Rogue Access Point
- Atacuri de tip DoS
- ...

Interceptarea traficului

- Identificarea AP-urilor și captarea pachetelor
- Atacatorul trebuie să se afle în aria de acoperire a rețelei
 - folosirea de antene direcționale pentru a putea asculta de la o distanță mai mare
- Atac folosit în faza de culegere de informații (recunoaștere)
- Unelte:
 - Wireshark (www.wireshark.com)
 - Kismet (www.kismetwireless.net)

- Enumerare rețele wireless active, sniffer de pachete și IDS
- Necesită plăci de rețea wireless care suportă *raw monitoring mode* (rfmon)
- Se compilează pe platforme Unix sau Windows (Cygwin)
- Arhitectură client-server
 - serverul colectează și interpretează date
 - clientul afișează datele colectate
- Drone
 - colectează pachete pe care le transmite către un server central
 - implementarea de sisteme distribuite de raportare și detectare intruziuni
- Unealtă extrem de puternică în special atunci când este combinată cu alte programe

Kismet (cont.)

```
dragorn@gir.lan.nerv-un.net: /home/dragorn
```

Network List—(Autofit)								Info
Name	T	W	Ch	Pkts	Flags	Data	Clnt	
p@thf1nd3r	A	Y	06	171		70	35	Ntwrks
<no ssid>	A	N	05	1		0	0	105
KrullNet1	A	Y	06	27		0	0	Pckets
linksys	A	N	06	81	FU4	8	2	1258
marley	A	N	06	312		17	1	Cryptd
<no ssid>	D	N	--	20	A2	20	18	104
! PARMAS	A	N	07	30		0	0	Weak
<no ssid>	A	Y	06	1		0	0	0
GRXWirelessNetwork	A	Y	06	2		0	0	Noise
! SECMAS	A	N	07	13		0	0	289
<no ssid>	D	N	--	1	A4	1	66	Discrd
! <Lucent Outdoor Router>	0	N	--	267		267	1	289
								Pkts/s
								50

Elapd
000027

Status

Found IP 159.139.90.1 for <no ssid>::00:04:76:BB:A7:04 via ARP
Found IP 159.139.90.1 for <no ssid>::00:04:76:BB:A7:04 via ARP
Found IP 159.139.90.1 for <no ssid>::00:04:76:BB:A7:04 via ARP
Found IP 159.139.120.13 for <no ssid>::00:B0:D0:DE:60:E3 via TCP

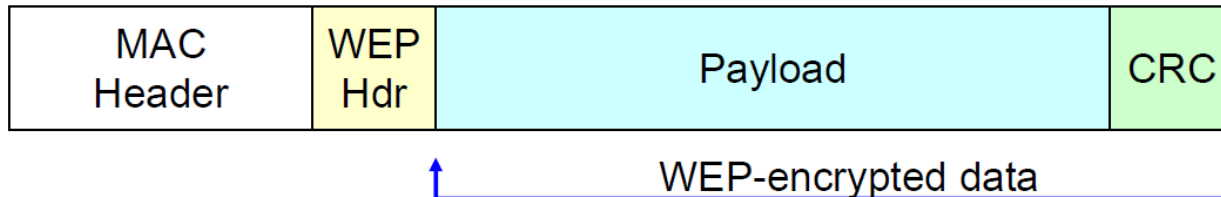
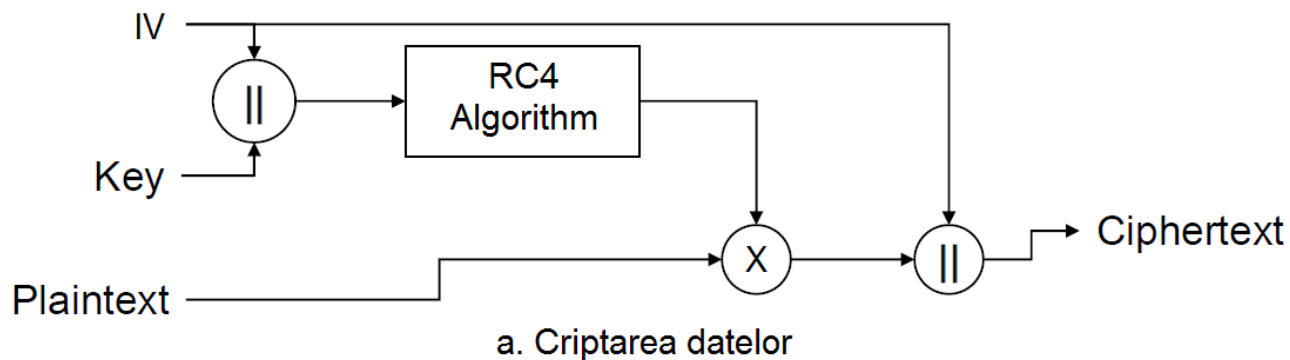
Battery: AC charging 100% 0h0m0s

Spargerea cheilor WEP

- **Wired Equivalent Privacy (WEP) este prima arhitectură de securitate pentru 802.11**
- **Asigură confidențialitatea și integritatea cadrelor de date**
 - cadrele de management nu sunt protejate!
- **Pentru criptarea datelor se folosește algoritmul RC4**
 - 40 biți Cheia Secretă + 24 biți IV = 64 biți (standard)
 - 104 biți Cheia Secretă + 24 biți IV = 128 biți (non-standard)
- **Pentru asigurarea integrității se adaugă la fiecare cadru un Integrity Check Value (ICV)**
 - CRC32 criptat cu RC4
- **A fost elaborat de nespecialiști**
 - multiple vulnerabilități de securitate

Spargerea cheilor WEP (cont.)

- Același procedeu / dispozitiv este folosit atât pentru criptarea cât și pentru decriptarea datelor
- Vectorul de inițializare (IV) trebuie să fie diferit pentru fiecare cadru
 - generat în mod aleator sau incrementat după fiecare cadru
- IV este transmis în clar, odată cu cadrul (în antetul WEP)
- CRC-ul este folosit pentru a verifica dacă decriptarea s-a efectuat corect



b. Formatul cadrelor

Spargerea cheilor WEP (cont.)

- Brute force
 - eficient pentru chei pe 40 biți
- Lungimea redusă a vectorului de inițializare (IV)
 - există 50% șanse ca același IV să se repete după 2^{12} cadre transmise în rețea!
 - nu asigură protecție împotriva retransmiterii de mesaje în rețea
- Modul de calcul al ICV permite, în anumite cazuri, modificarea datelor
- Unelte:
 - suita *aircrack-ng* (www.aircrack-ng.org)
 - airmon-ng – pune placa de rețea în monitoring mode
 - airodump-ng – sniffer de pachete
 - aireplay-ng – injectarea de pachete în rețea
 - aircrack-ng – spargere chei WEP și WPA / WPA2 (atacuri de tip dicționar)
 - airdecap-ng – decriptare pachete WEP și WPA / WPA2 cu o cheie dată
 - tutoriale <http://www.aircrack-ng.org/doku.php?id=tutorial>

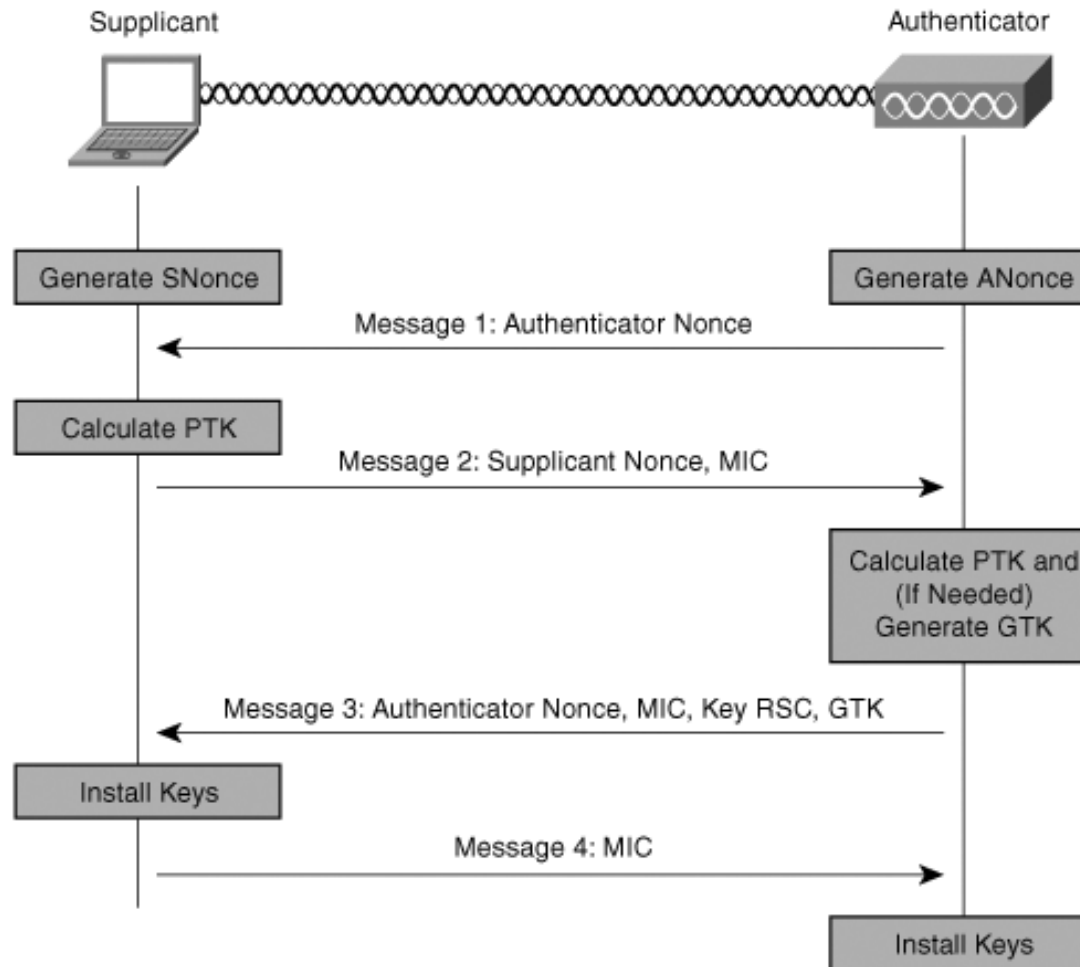
Spargerea cheilor WEP folosind aircrack-ng

1. Se trece placa de rețea în monitoring mode, pe canalul folosit de AP
`# airmon-ng start wlan0 9`
2. Se testează dacă injectarea de pachete în rețea funcționează
`# aireplay-ng -9 -e <ESSID> -a <AP MAC> mon0`
3. Se începe captarea pachetelor
`# airodump-ng -c 9 --bssid <AP MAC> -w output mon0`
4. Se face o încercare falsă de autentificare la AP
`# aireplay-ng -1 0 -e <ESSID> -a <AP MAC> -h <STA MAC> mon0`
5. Se captează și se reinjectează în rețea cereri ARP pentru a obține cât mai multe valori IV
`# aireplay-ng -3 -b <AP MAC> -h <STA MAC> mon0`
6. Se extrage cheia din datele captate
`# aircrack-ng -b <AP MAC> output*.cap`

Spargerea cheilor WPA / WPA2

- Specificații elaborate de experți
- Confidențialitatea și integritatea datelor
 - TKIP (RC4)
 - considerat ca fiind depreciat începând cu Ianuarie 2009
 - CCMP (AES)
- Metode de autentificare
 - Pre-Shared Key (PSK)
 - IEEE 802.1x + EAP
 - Wi-Fi Protected Setup (WPS)
 - se recomandă a se dezactiva!
- KRACK attack (2017) 😊

Spargerea cheilor WPA / WPA2 (cont.)



Spargerea cheilor WPA / WPA2 (cont.)

- **Atacuri posibile**
 - brute force
 - dictionar
- **Pentru a putea efectua atacul trebuie înregistrat schimbul de mesaje din 4-way handshake**
 - forțarea clienților să se deautentifice și apoi să se autentifice din nou la AP
- **Unelte:**
 - cowpatty (www.willhackforsushi.com)
 - suita aircrack-ng (www.aircrack-ng.org)
 - oclHashcat (hashcat.net/oclhashcat/)
 - procesare paralelă (GPU)

Spargerea cheilor WPA / WPA2 folosind aircrack-ng

1. Se trece placa de rețea în monitoring mode, pe canalul folosit de AP

```
# airmon-ng start wlan0 9
```

2. Se începe captarea pachetelor

```
# airodump-ng -c 9 --bssid <AP MAC> -w output mon0
```

3. Se deautentifică un client de la AP

```
# aireplay-ng -0 1 -a <AP MAC> -c <TARGET MAC> mon0
```

4. Se încearcă spargerea cheii folosind un atac de tip dicționar

```
# aircrack-ng -w password.lst -b <AP MAC> output*.cap
```

WiFi Protected Setup (WPS)



- Protocol utilizat în rețelele wireless pentru simplificarea diferitelor acțiuni precum adăugarea de noi echipamente într-o rețea configurată cu WPA
- Folosește un PIN de 8 cifre pentru autentificarea noilor echipamente
- Protocolul are o vulnerabilitate de design (2011) ce permite recuperarea PIN-ului prin forță brută
 - PIN = xxxxyyyz
 - z suma de control pentru celelalte cifre
 - la autentificare, validitatea PIN-ului este raportată diferit pentru grupele xxxx și yyy
- Rezultă max $10000 + 1000 = 11000$ încercări pentru a descoperi PIN-ul. Pe baza PIN-ului se poate afla cheia WPA!
- Unelte:
 - *reaver* (code.google.com/p/reaver-wps/)

Spargerea cheilor WPS folosind aircrack-ng

1. Se trece placa de rețea în monitoring mode

```
# airmon-ng start wlan0
```

2. Se detectează rețelele wireless cu WPS activat

```
# wash -i mon0
```

3. Se incepe atacul brute force (aprox. 4-6 ore)

```
# reaver -i mon0 -b 00:22:15:31:89:18 -vv
```

Rogue Access Point

- **Rogue AP = AP neautorizat conectat în rețeaua organizației**
 - backdoor pentru accesul în rețea
 - ocolirea mecanismelor de securitate implementate la nivel rețea (Firewall, IDS, etc)
- **Evil Twin = AP cu același SSID și adresă MAC ca a unui legitim**
 - conectat, de regula, în Internet
 - interceptare trafic, atacuri de tip MITM supra clienților
 - atacatorul trebuie să se afle în vecinătatea țintei
- **Unelte**
 - *airbase-ng* (<http://www.aircrack-ng.org>)
 - *AirSnarf* (<http://airsnarf.shmoo.com>)

Atacuri de tip DoS

- Cadrele de management în 802.11 nu sunt protejate
- Autentificarea originii cadrelor 802.11 se face pe baza adreselor MAC care pot fi ușor falsificate
- Traficul poate fi ușor interceptat sau bruiat
- Tipuri de atacuri DoS:
 - authentication / association flood attack
 - deauthentication / disassociation attack

Authentication / association flood attack

- Transmiterea unui număr mare de cereri de tip *authentication* / *association* către AP cu scopul de a epuiza resursele acestuia și a bloca astfel accesul stațiilor la rețea
- Unele:
 - `void11` (www.wlsec.net/void11)

```
# void11_penetration wlan0 -D -t <type of attack> -s  
<STA MAC> -S <ESSID> -B <AP MAC>
```


Deauthentication / disassociation attack

- Transmiterea de comenzi de tip *deauthentication* / *disassociation* către stațiile conectate la un AP
- Unele:
 - suita *aircrack-ng* (www.aircrack-ng.org)
`# aireplay-ng -0 25 -a <AP MAC> -c <TARGET MAC> mon0`
 - *file2air* (www.willhackforsushi.com) – injectarea de pachete în rețea
`# file2air -i mon0 -n 25 -d <DST MAC> -s <SRC MAC> -b <AP MAC> -f packets/deauth.bin`



5. Testarea securității rețelelor



Scopul testelor de securitate

- **Feedback cu privire la eficiența măsurilor de securitate implementate**
 - îmbunătățire continuă a securității sistemelor
- **Demonstrarea complianței cu standardele și reglementările în vigoare**
- **Activitate repetitivă**
- **Abordări:**
 - Vulnerability Scanning
 - Penetration Testing / Etical Hacking
- **Metodologii**
 - Open Source Security Testing Methodology Manual (OSSTMM)
 - NIST SP 800-115 “Technical Guide to Information Security Testing and Assessment”

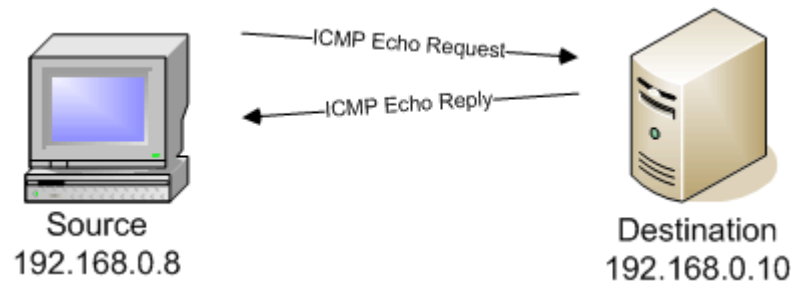
Unelte uzuale

- Scanere de porturi
- Scannere de vulnerabilități
- ...

Scanere de porturi

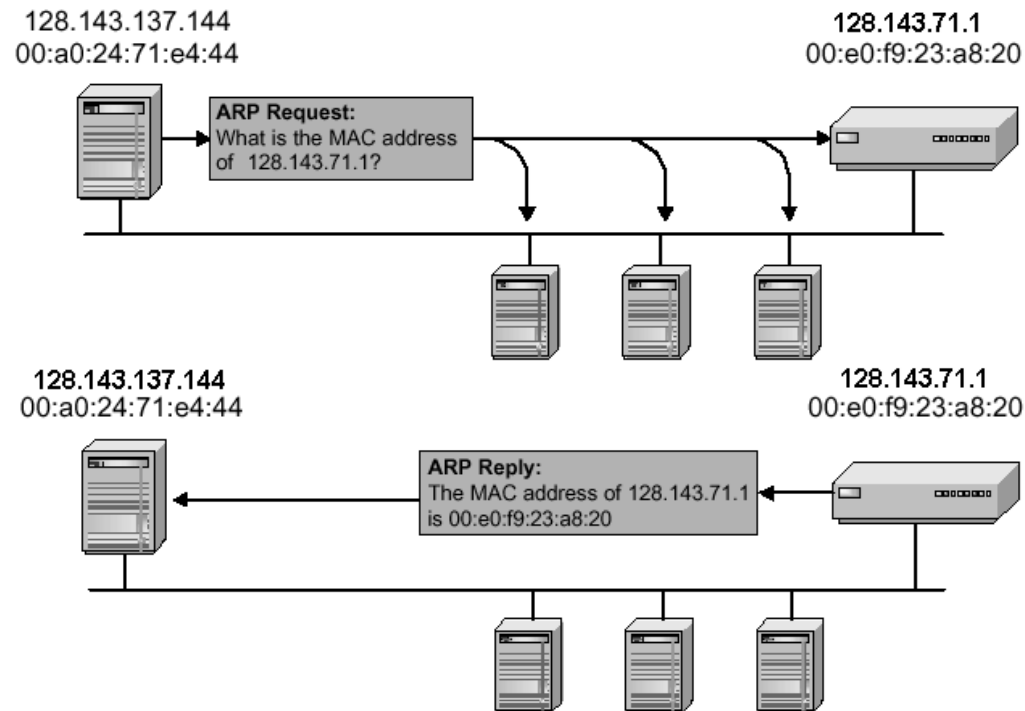
- **Identificarea calculatoarelor active din rețea, determinarea porturilor de deschise și a serviciilor asociate**
- **Culegere de informații despre rețea (network mapping tool)**
- **Tehnici de scanare:**
 - ICMP Ping
 - ARP Ping
 - TCP connect() Scan
 - TCP SYN Scan
 - TCP FIN, Xmas Tree, Null Scan
 - UDP Scan

ICMP Ping



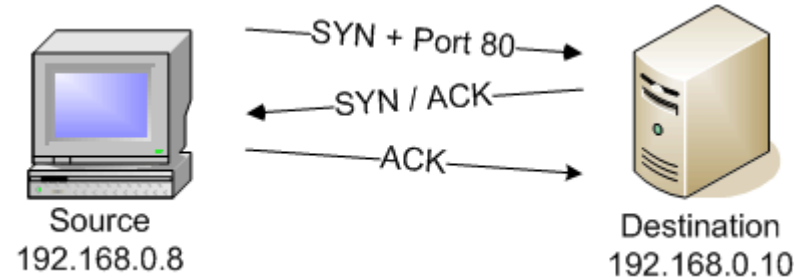
- **Interogări ICMP**
 - ICMP ECHO_REQUEST (Type 8)
 - ICMP ECHO_REPLY (Type 0)
- **Poate fi blocat de network firewall / personal firewall**
- **Unelte:**
 - ping / fping
 - nmap -PE
 - hping3 --icmp

ARP Ping



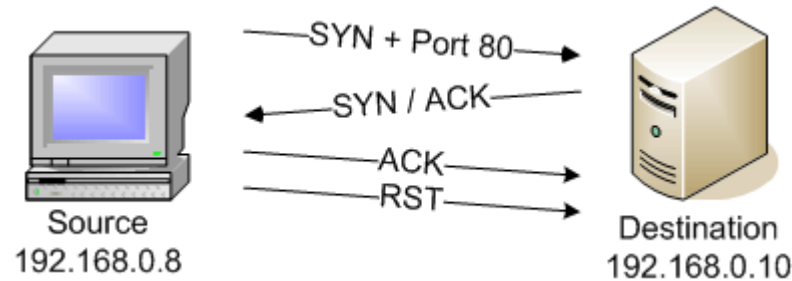
- Permite descoperirea numai a sistemelor din rețeaua locală
- Unele:
 - arping
 - nmap -PR

Scanare porturi TCP



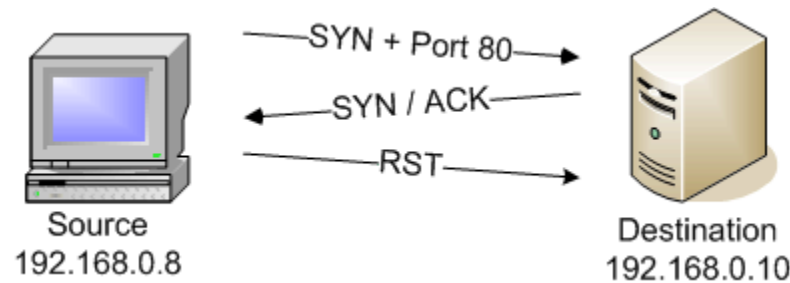
- Deschiderea unei conexiuni se face prin **three-way handshake**
 - SYN -> SYN+ACK -> ACK
- Se trimite un pachet cu flagul SYN setat
 - dacă ținta răspunde cu SYN+ACK, atunci portul este *deschis (open)*
 - dacă țintă răspunde cu RST, atunci portul este *închis (closed)*
 - dacă ținta nu răspunde, atunci portul este *filtrat (filtered)*

TCP Connect() Scan



- Metodă de scanare simplă și rapidă
- Creează conexiuni TCP complete
- Apelurile connect() sunt jurnalizate
netstat
- Unele:
telnet
nmap -sT

TCP SYN Scan

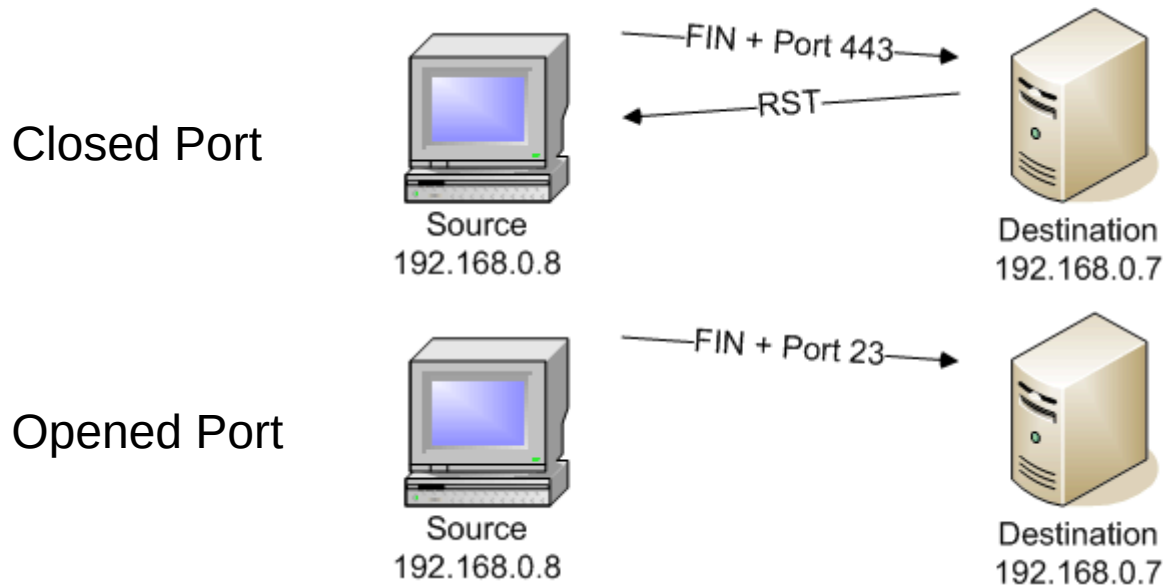


- **Conexiuni pe jumătate deschise (half open connection)**
 - se transmite un pachet SYN pentru a cere deschiderea conexiunii
 - după recepționarea unui SYN/ACK se renunță la conexiune trimițându-se un pachet RST
- **Greu de detectat**
 - majoritatea IDS și firewall-urilor nu interpretează pachetele SYN
- **Unelte:**
 - # nmap -sS
 - # hping3 --syn

TCP FIN, Xmas Tree, Null Scan

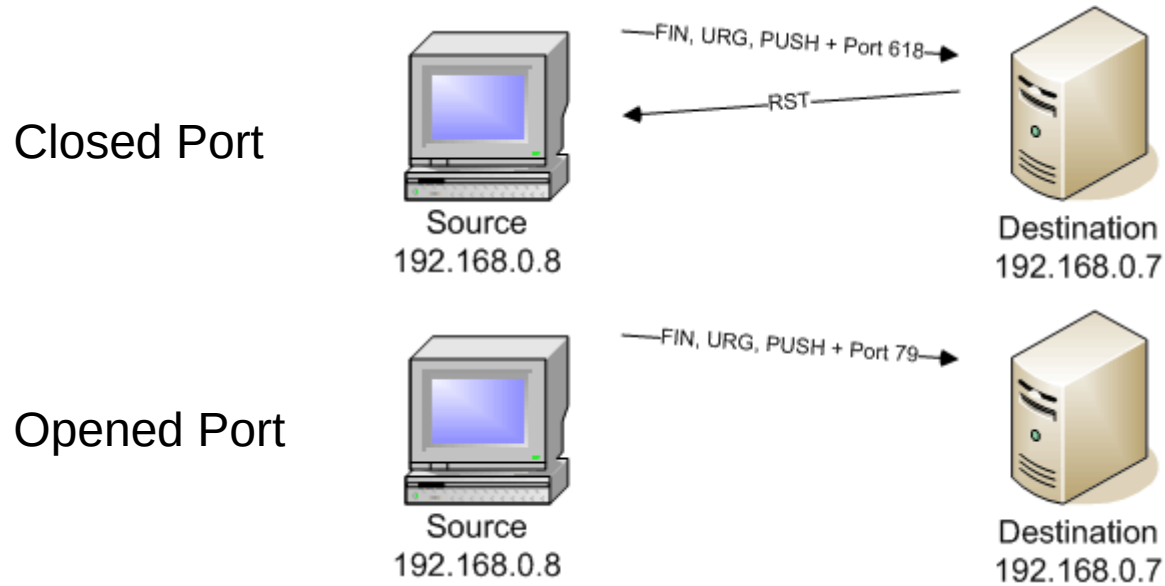
- **Principiul de funcționare este același**
 - manipularea biților de control (flags) din antetul pachetelor TCP
 - pachete atipice (ce nu pot și întâlnite în realitate)
- **Conform RFC 793, atunci când un sistem primește un pachet pe un port închis, trebuie să răspundă cu un RST**
 - dacă nu se recepționează nici un RST înseamnă că portul este deschis sau comunicația este filtrată de firewall
- **Nu funcționează în cazul sistemelor Windows, Cisco, IBM OS/400 (returnează RST chiar dacă portul este deschis)**

TCP FIN Scan



- Se trimite din prima un pachet TCP având flag-ul FIN setat
- Unele:
 - nmap -sF
 - hping3 --fin

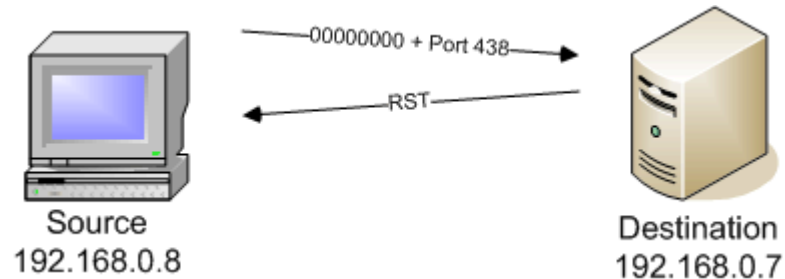
TCP Xmas Tree Scan



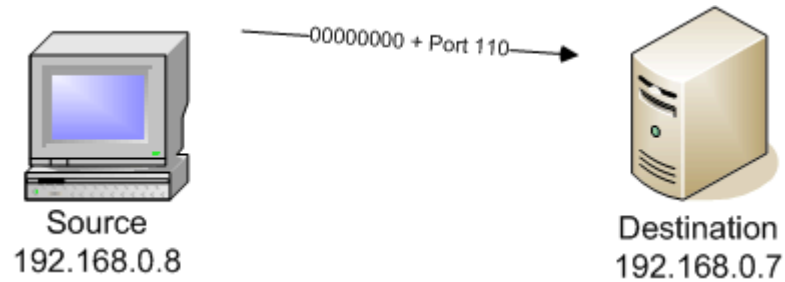
- Se trimite din prima un pachet TCP având flag-urile FIN, URG și PUSH setate
- Unelte:
 - nmap -sX
 - hping3 --fin --urg --push

TCP Null Scan

Closed Port



Opened Port



- Se trimite din prima un pachet TCP fără nici un flag setat
- Unele:
 - nmap -sN
 - hping3

Alte scanări TCP

■ TCP ACK Scan

- folosit pentru a determina tipul de firewall (stateless / stateful) și porturile filtrate de acesta
- dacă firewall-ul este stateless și accesul la sistem este permis, porturile deschise și închise vor returna RST

nmap -sA

■ TCP Window Scan

- Similar cu TCP ACK Scan
- examinarea dimensiunii ferestrei TCP din pachetele RST primite ca răspuns. Dacă dimensiunea ferestrei este diferită de zero, portul este deschis

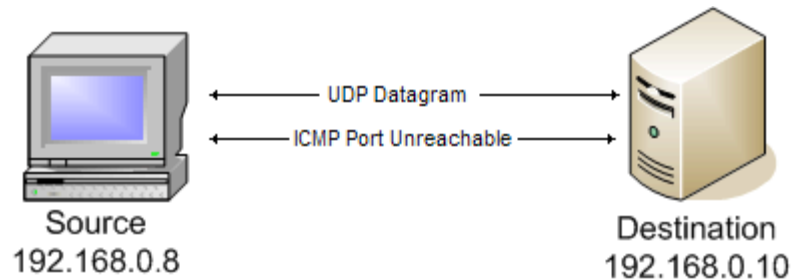
nmap -sW

■ TCP Idle Scan

- scanare indirectă prin intermediul unui zombie

nmap -sl

UDP Scan



- Similar unui TCP scan dar cu pachete UDP
- Se transmit pachete UDP către porturile de pe calculatorul țintă. Dacă nu apare nici o eroare ICMP atunci portul este posibil să fie deschis sau filtrat de firewall
- Proces lent
 - timp de răspuns mare 1-4 sec
- Unele:
 - # nmap -sU
 - # hping3 --udp

OS Fingerprinting

- RFC-urile nu conțin specificații complete
- Diferențe subtile în implementarea stivei TCP/IP
 - TTL (time-to-live)
 - Numerele de secvență inițiale
 - Window size
 - DF (Don't fragment bit)
 - ...
- Passive fingerprinting
 - analiza pachetelor care trec prin dreptul stației de observare
 - precizie scăzută
- Active fingerprinting
 - trimiterea de pachete către țintă pentru a vedea cum se comportă
 - precizie ridicată

Passive OS fingerprinting

- p0f (<http://lcamtuf.coredump.cx/p0f.shtml>)
- Analiza pachetelor TCP transmise de stații
- p0f output

```
<Wed Feb 27 18:26:58 2008> 213.215.x.x:45291 - Linux 2.6
    (newer, 2) (up: 1421 hrs) -> 208.83.x.x:2703 (distance 0,
    link: ethernet/modem)

<Wed Feb 27 18:27:02 2008> 212.24.x.x:62994 - FreeBSD 5.3-
    5.4 (up: 4556 hrs) -> 213.215.x.x:80 (distance 9, link:
    ethernet/modem)

<Wed Feb 27 18:27:16 2008> 90.2.x.x:1322 - Windows 2000 SP4,
    XP SP1+ -> 213.215.x.x:80 (distance 9, link: pppoe (DSL))
```

Active OS fingerprinting

- nmap -O
- 7 probe TCP, 1 ICMP, 1 UDP, la interval de 110 milisecunde



The screenshot shows a terminal window with a menu bar (Session, Edit, View, Bookmarks, Settings, Help) and a title bar (root@1[knoppix]). The terminal displays the command `nmap -O 10.0.0.10` and its output. The output includes the nmap version (3.75), the target IP (10.0.0.10), a list of open ports and services, the MAC address (00:02:B3:41:08:B8), the device type (general purpose), the running OS (Linux 2.4.X|2.5.X|2.6.X), and the OS details (Linux 2.4.0 - 2.5.20, Linux 2.4.18 - 2.6.7). The terminal also shows the completion of the nmap run and the prompt `root@1[knoppix]#`.

```
Session Edit View Bookmarks Settings Help

root@1[knoppix]# nmap -O 10.0.0.10

Starting nmap 3.75 ( http://www.insecure.org/nmap/ ) at 2005-11-14 21:13 EST
Interesting ports on server.homelan.net (10.0.0.10):
(The 1653 ports scanned but not shown below are in state: closed)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
53/tcp    open  domain
80/tcp    open  http
111/tcp   open  rpcbind
139/tcp   open  netbios-ssn
443/tcp   open  https
445/tcp   open  microsoft-ds
3128/tcp  open  squid-http
3306/tcp  open  mysql
MAC Address: 00:02:B3:41:08:B8 (Intel)
Device type: general purpose
Running: Linux 2.4.X|2.5.X|2.6.X
OS details: Linux 2.4.0 - 2.5.20, Linux 2.4.18 - 2.6.7

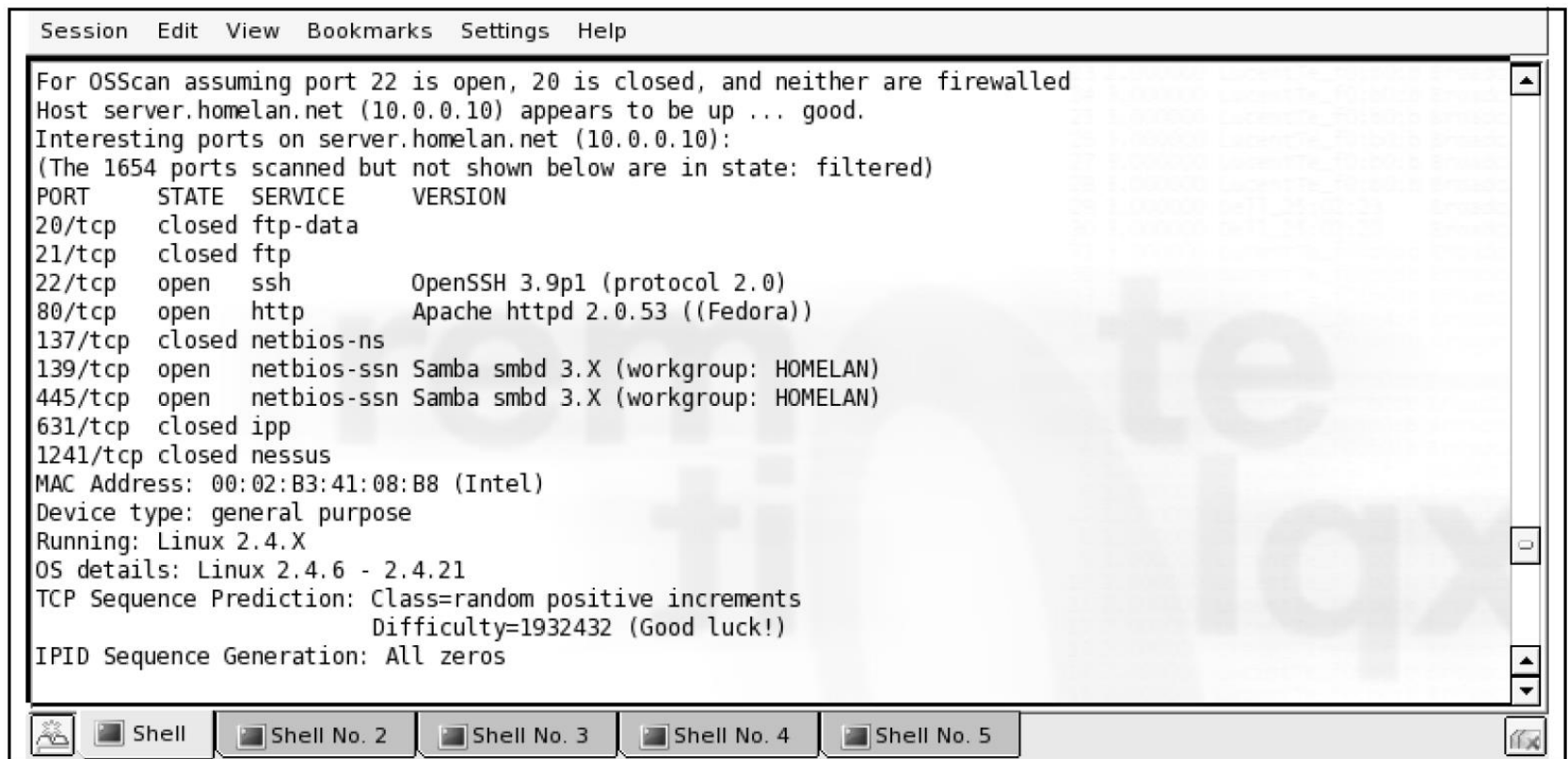
Nmap run completed -- 1 IP address (1 host up) scanned in 2.567 seconds
root@1[knoppix]#
```

Identificarea serviciilor

- **Banner grabbing**
 - foarte multe servicii “se prezintă” în momentul conectării
 - Apache/2.4.41 (Ubuntu)
 - SSH-2.0-OpenSSH_7.9p1 Debian-10
- **Amprentare**
 - transmiterea de pachete personalizate și compararea răspunsului cu o bază de date cu semnături
- **Unelte:**
 - # telnet
 - # nmap
 - # amap
 - # httpprint

Banner Grabbing (cont.)

- **nmap -sV**
- **Detectarea versiunii serviciilor**



```
Session Edit View Bookmarks Settings Help

For OSScan assuming port 22 is open, 20 is closed, and neither are firewalled
Host server.homelan.net (10.0.0.10) appears to be up ... good.
Interesting ports on server.homelan.net (10.0.0.10):
(The 1654 ports scanned but not shown below are in state: filtered)
PORT      STATE SERVICE      VERSION
20/tcp    closed ftp-data
21/tcp    closed ftp
22/tcp    open  ssh          OpenSSH 3.9p1 (protocol 2.0)
80/tcp    open  http         Apache httpd 2.0.53 ((Fedora))
137/tcp   closed netbios-ns
139/tcp   open  netbios-ssn Samba smbd 3.X (workgroup: HOMELAN)
445/tcp   open  netbios-ssn Samba smbd 3.X (workgroup: HOMELAN)
631/tcp   closed ipp
1241/tcp  closed nessus
MAC Address: 00:02:B3:41:08:B8 (Intel)
Device type: general purpose
Running: Linux 2.4.X
OS details: Linux 2.4.6 - 2.4.21
TCP Sequence Prediction: Class=random positive increments
                      Difficulty=1932432 (Good luck!)
IPID Sequence Generation: All zeros
```

Shell Shell No. 2 Shell No. 3 Shell No. 4 Shell No. 5

Vulnerabilități

- Eroare de programare sau greșeală de configurare ce poate crea breșe în securitatea sistemelor
- Dacă nu sunt corectate la timp pot fi exploatare de către un eventual atacator
- Metode de corecție
 - instalare de patch-uri recomandate de producător
 - securizarea sistemelor (hardening)

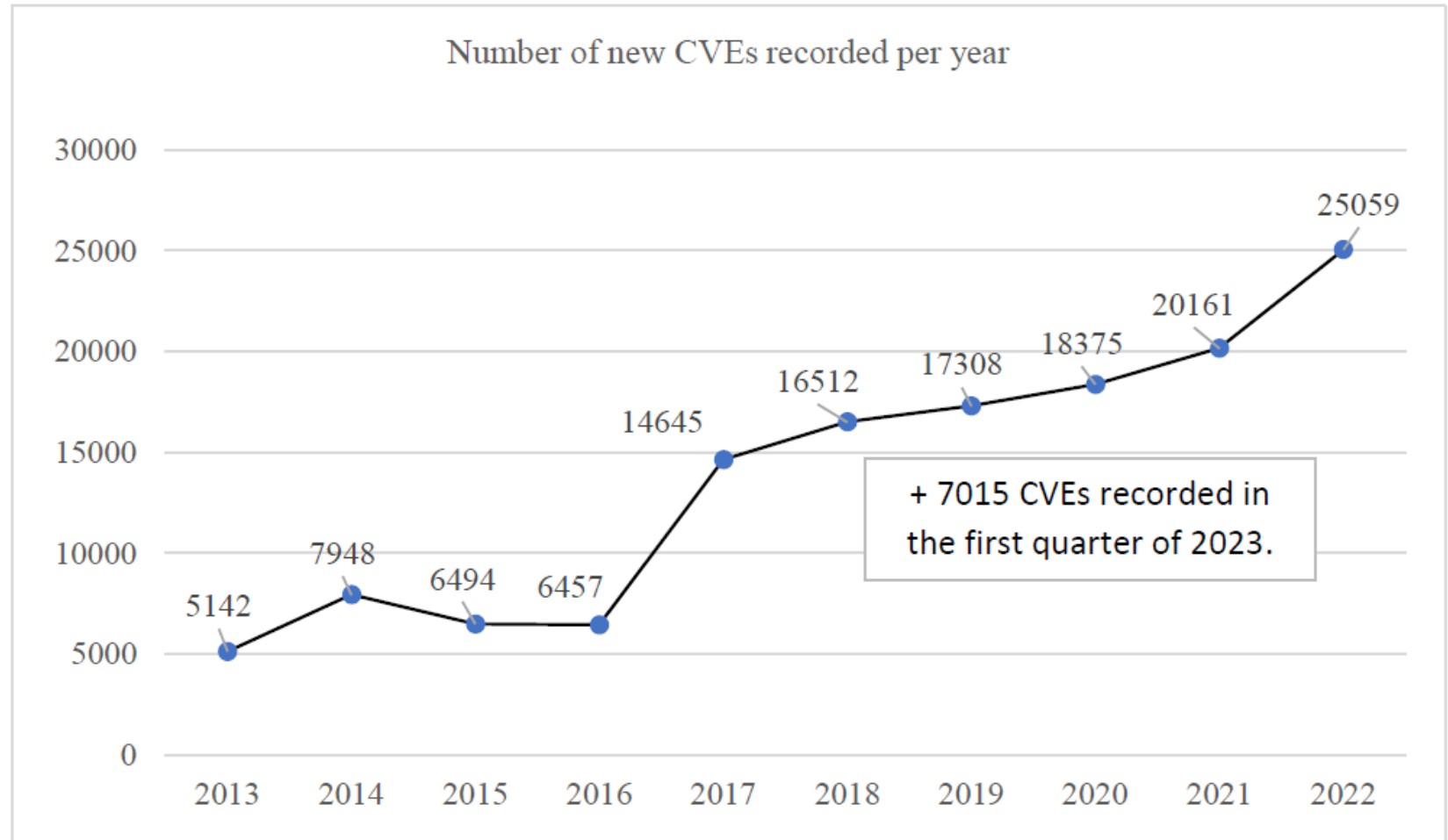
Vulnerabilități (cont.)

- Validarea insuficientă a datelor de intrare
- Ocolirea mecanismelor de autentificare
- Expunerea datelor senzitive
- Buffer Overflow
- Coruperea Heap-ului
- ...

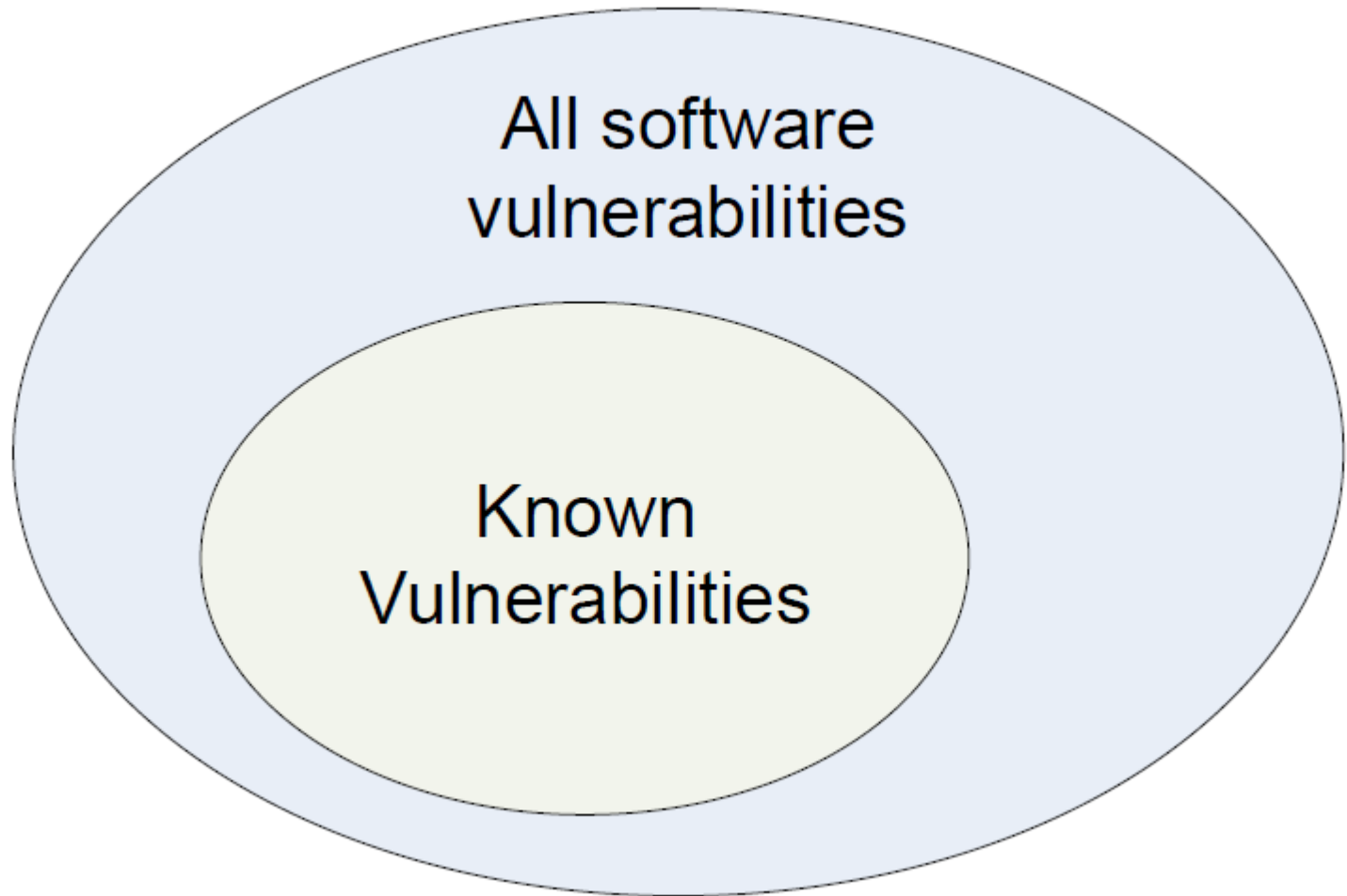
Vulnerabilități (cont.)

- Peste 100.000 vulnerabilități cunoscute
- Common Vulnerabilities and Exposures (CVE)
 - lista cu denumirile standardizate ale tuturor vulnerabilităților cunoscute
 - dicționar de vulnerabilități (nu bază de date)
 - <http://cve.mitre.org/>
- Baze de date de vulnerabilități
 - National Vulnerability Database (<http://nvd.nist.gov/>)
 - Secunia Advisory and Vulnerability Database (<http://secunia.com/>)
 - Open Source Vulnerability Database (<http://osvdb.org/>)
 - SecurityFocus (<http://www.securityfocus.com/>)

Vulnerabilități (cont.)



Vulnerabilități (cont.)



Tehnici de descoperire a vulnerabilităților

- **Static structural analysis**
 - Source code review
 - Binary code analysis / Reverse code engineering
- **Dynamic structural testing**
 - înregistrarea apelurilor de funcții efectuate de aplicație
- **Fuzz testing**
 - testarea aplicațiilor folosind date de intrare invalide / aleatoare
 - testare negativă

Scannere de vulnerabilități

- **Automatizarea procesului de identificare și corectare a vulnerabilităților**
 - permit detectarea numai a vulnerabilităților cunoscute!
- **Clasificare**
 - funcție de locație de unde se face scanarea
 - network based
 - host based
 - funcție de credențialele folosite pe parcursul scanării
 - cu drepturi administrative
 - fără drepturi administrative
 - funcție de tipul de sisteme / aplicații testate
 - de uz general
 - pentru aplicații web

Scannere de vulnerabilități (cont.)

- OpenVAS (<https://www.openvas.org/>)
 - Nuclei (<https://github.com/projectdiscovery/nuclei>)
 - Nessus (<https://www.nessus.org>)
 - Rapid7 Nexpose (<https://www.rapid7.com/>)
 - GFI LANGuard (<https://www.gfi.com>)
 - QualysGuard (<https://www.qualys.com/>)
- <https://sectools.org/tag/vuln-scanners/>

Resurse utile

- **NIST Special Publications**
 - <http://csrc.nist.gov/publications/nistpubs/>
- **NSA Security Configuration Guides**
 - <http://www.nsa.gov/snac/>
- **Center for Internet Security**
 - <https://www.cisecurity.org/>
- **Security Onion Distro**
 - colecție de unelte pentru monitorizarea securității rețelelor
 - <https://securityonionsolutions.com/>

